

REPLICANT: Learning Policies for Evading and Hardening Malware Detectors

Shae McFadden^{†‡§}, Ilias Tsingenopoulos[¶], Mario D’Onghia[§], Alexander Herzog^{§||},
 Myles Foley^{‡*}, Chris Hicks[‡], Lorenzo Cavallaro[§] Fabio Pierazzi[§]
[†]King’s College London, [‡]The Alan Turing Institute, [§]University College London,
[¶]KU Leuven, ^{||}Core64, ^{*}Devotion AI Labs

Abstract

To determine the real-world effectiveness of *machine learning* based malware detection, it is vital to evaluate its robustness against highly capable adversaries. However, state-of-the-art attacks do not effectively model realistic adversaries, as they often assume access to privileged information such as the training data, feature space, or confidence scores of the target. In this work, we present REPLICANT, a deep reinforcement learning framework that *learns the realistic task* of evasion under a *strict label-only black-box threat model*. REPLICANT learns a reusable policy on *how* to modify a malware sample and *when* to query the target, which transfers across samples, detectors, and feature spaces. Across seven Android malware detectors and three feature spaces, REPLICANT is the strongest and most query-efficient approach achieving a mean attack success rate of 78.8%, a relative improvement of 20.9%–39.2% over the state-of-the-art. Furthermore, when used for adversarial training, REPLICANT also outperforms the state-of-the-art by producing detectors with more generalizable robustness. With REPLICANT we demonstrate that learning the task of evasion not only results in stronger attack performance but, crucially, provides a better signal for hardening malware detectors.

1 Introduction

Machine Learning (ML) classifiers have become a key line of defence against malware, with extensive research focusing on improving their performance and robustness to drift [4, 6, 16, 39, 46, 47, 51, 57, 80, 82] and Android being an ideal target for malware as it is the most widely used mobile operating system globally [72]. However, the field of Adversarial Machine Learning (AML) has repeatedly demonstrated the brittleness of ML-based systems under targeted modifications [8, 9, 14, 33]. Although well established, this vulnerability is often underpinned with strong assumptions, such as access to confidence scores; therefore, the question most relevant for risk assessment is not *whether* these detec-

tors can be evaded, but how *general* and *efficient* an attack can be under realistic constraints.

Most evasion research operates in the *feature space*, directly modifying the input that is fed into ML systems [9, 14, 33]. Although sufficient to evade systems such as image detection, these approaches are not applicable to crafting evasive malware due to the *inverse mapping problem*: a change to the feature vector does not necessarily correspond to any realizable and function-preserving change in the application [11, 19, 35, 59, 61, 65, 69]. Alternatively, *problem-space* attacks avoid this problem by modifying the application directly while enforcing syntactical and semantic constraints; therefore, every adversarial example is a valid program by construction.

Despite the shift towards more realistic problem-space evasion, the Android evasion literature is still *fragmented* with three major limitations. First, existing works optimize individual samples against a single target classifier and feature space, relying on confidence scores and search heuristics or greedy selection [11, 35, 59]. As a result, these attacks optimize on a per-sample basis without retaining knowledge from past evasions, capping their query efficiency and limiting their transferability to new targets. Second, existing literature often conflates two separate components of problem-space attacks: (i) the *capability set*, which defines modifications available to the attacker that can be made while preserving problem-space constraints; and, (ii) the *strategy*, which selects from the capability set in order to modify a sample to evade a target. Therefore, when both components are proposed together and not evaluated in isolation, it is unclear if the new attack has discovered a better strategy for evasion, or if a potentially sub-optimal strategy is being carried by a stronger capability set. This ambiguity is a form of the gain attribution pitfall raised by [50]. Finally, these approaches are evaluated only on a single temporal snapshot, ignoring the impact that temporal drift and targets that employ Active Learning (AL) [67] have on the evasion of malware samples. We therefore lack a comprehensive understanding of how evasion strategies generalize and transfer across *classifiers*, *feature spaces*, and *time*.

To address these limitations, we propose REPLICANT: a unified Deep Reinforcement Learning (DRL) framework that *learns* problem-space evasion policies. Evasion here is formulated as a sequential decision-making problem (specifically, a Markov Decision Process) where an agent observes the current representation of a modified malware sample and chooses either: (i) to submit the sample to the target; or, (ii) to modify the sample and select which capability to apply. REPLICANT is deliberately agnostic to *what* the problem-space capabilities are: it learns effective evasion policies given *any* capability set and a representation that captures how the modifications affect the sample. For Android malware detection, one of the most common capabilities is the harvesting and transplantation of self-contained code fragments from benign applications [11, 19, 35, 59]. Concretely, we instantiate our capability set using gadget transplantation as proposed in [19, 59].

In this work we evaluate REPLICANT under five key settings. First, we establish REPLICANT as a state-of-the-art black-box attack, comparing it to prior attacks [11, 35, 44, 59, 60, 63, 69, 79], in the largest Android malware evasion study to date. Second, we demonstrate the advantage of learned policy-transfer over sample-transfer across all 1,764 surrogate and target combinations. Third, we investigate the defensive utility of the REPLICANT attack through the use of a white-box variant (REPLICANT_{WB}) to produce robust targets through Adversarial Training (AT), AT-REPLICANT, comparing it with the white-box attack APG (APG_{WB}/AT-APG) [59]. Fourth, we assess how well this robustness from AT withstands an evolving attacker capability set. Lastly, we explore the interplay between AL and AT when evaluating both clean performance and adversarial robustness over time. In summary, we make the following contributions:

- **REPLICANT Framework.** We propose REPLICANT, a general DRL-based framework that learns problem-space evasion over a capability set as a *hierarchical policy*, improving Attack Success Rate (ASR) by 20.9%–39.2% compared to state-of-the-art Android attacks.
- **Policy Transfer.** We demonstrate that a policy trained against a surrogate transfers more effectively than the samples that evade the same surrogate, yielding an 82.0% relative increase in ASR.
- **AT & Capability Drift.** We show that AT-REPLICANT reduces attacker success below 17% for *both* REPLICANT_{WB} and a APG_{WB}, whereas AT-APG leaves the model over five times more vulnerable to REPLICANT_{WB}. We also show that the robustness gained from AT diminishes as the attacker capabilities expand from the capability set used by the defender.
- **Robustness under Drift.** We establish that applying AL directly to AT hardened classifiers recovers drift-induced performance but degrades robustness, whereas

our Robust AL (RAL) retains the performance-over-time of AL and the robustness of AT.

- **Comprehensive Study.** We conduct the largest evaluation of problem-space Android malware evasion to date, comprising 379,680 attack evaluations, isolating the gains of evasion strategies on attacker success.

2 Background

2.1 Android Malware Detection

We evaluate this work in the Android malware domain due to the extensive work eliminating experimental bias in evaluations [58] and dataset composition [18] with AndroZoo [2] supplying the large-scale, representative, and timestamped corpus on which these bias mitigations depend on.

Representations. The dominant pipeline in Android malware detection consists of extracting *static* features from the manifest, alongside the bytecode of the application, and encoding each sample as a high-dimensional binary vector. The three feature spaces used in this work are: *Drebin* [4], the de facto standard in the domain, which spans permissions, API calls, intents, hardware components, and network addresses; *API-Graph* [80], which enriches the *Drebin* feature space with clustering-based representations. *APIGraph* maps functionally similar APIs to the same primitive, which reduces temporal drift due to software-evolution. Lastly, *RAMDA* [47], which, as a subset of the *Drebin* feature space, covers API calls, intents, and permissions. The variable size and overlap between these three feature spaces allows us to evaluate scenarios in which the attacker has varying degrees of knowledge of the feature space the target detector is trained on.

Detection. Based on these features, the community has developed a diverse set of detection methodologies: linear models ranging from the original Drebin SVM [4] to the robust variant SecSVM [21]; ensemble methods such as Random Forests (RF) [57, 77]; and deep learning approaches including Deep Drebin [34], the robust android malware detection algorithm (RAMDA) classifier [47], the hierarchical contrastive classifier (HCC) [16], and the deep reinforcement malware detector (DRMD) [51]. This spectrum allows us to assess the general performance and transferability of attacks between diverse models and detection methodologies.

Temporal Drift. Finally, a major challenge in malware detection is *temporal drift*. We use temporal drift as an umbrella term for covariate shift, prior probability shift, and concept shift [56]. Since both goodware and malware evolve over time, the test distribution diverges from the training distribution, degrading performance-over-time [18, 41, 52, 53, 58]. Therefore, training without temporally consistent splits or testing on unrealistic class-ratios can substantially inflate performance [41, 58]. We follow the recommendations of *Tesseract* [58] and the guidelines of [3], adopting time-aware splits

with a realistic malware distribution ($\approx 10\%$) and an explicit temporal evaluation. Critically, as malware authors continuously adapt to avoid detection and improve functionality, drift in this domain is, at least in part, intrinsically intertwined with the objective of evasion.

2.2 Evasion Attacks

Evasion attacks perturb the inputs of an ML system at test-time in order to cause misclassification. Specifically, in the context of malware detection, evasion attacks modify malware samples to be classified as goodware while retaining their original behavior. In practice, access to the actual target model is limited; thus, the two predominant strategies of transferability and querying attacks were developed to make attacks practical. *Transferability* attacks leverage a surrogate model to optimize an Adversarial Sample (AE) and rely on decision boundary similarity to evade the target [22]. Alternatively, *Querying* attacks interact with the target directly, submitting successive versions of an AE and using the feedback received to guide evasion while minimizing queries [12, 15, 20]. REPLICANT combines both of these methodologies by learning an evasion policy on a surrogate (transferability) and then uses that policy to choose *what* to modify and *when* to submit new malware samples to the target (querying).

Inverse Mapping Problem. Feature-space attacks perturb the feature vector directly, similarly to evasion attacks in computer vision, where pixels are modified via gradient-based perturbations [14, 25, 27, 33, 43, 49, 55, 68]. In the context of the predominantly binary feature spaces of Android malware detection, adding a feature ($0 \rightarrow 1$) requires concretely introducing the corresponding code (such as API or permission), while removing a feature ($1 \rightarrow 0$) may require removing or breaking functionality that is central to the malware. As a result, when the representation reflects real programs, the feature extraction process is often lossy, giving rise to the *inverse mapping problem* [19, 59] as the feature mapping from the problem space is neither invertible nor differentiable.

Problem-Space Evasion. Problem-space attacks circumvent the inverse-mapping problem by grounding modifications in the program itself, with each transformation mapping actual code to a known feature space effect [19, 59]. Using the formalization by [59], problem-space attacks must meet the following criteria: (i) *available transformations (realizability)*, using only modifications an attacker could perform in practice; (ii) *preserved semantics*, the transformations performed must preserve the original malicious behavior of the sample; (iii) *plausibility*, the sample should appear realistic upon manual inspection; (iv) *robustness to preprocessing*, the modifications should survive a realistic pre-processing pipeline. The most established way to satisfy these constraints for problem-space Android malware attacks is *gadget extraction and transplantation*, where self-contained code fragments alongside their known features are harvested from benign applications and

transplanted into malware [10, 11, 19, 35, 59, 78]. As a result of gadgets being harvested from real applications, they are realizable and plausible by construction. Furthermore, since gadget transplantation only *adds* benign code, and thus features ($0 \rightarrow 1$), it preserves the original behavior (semantics) of the malware. Therefore, given a set of gadgets, problem-space evasion is then reduced to finding effective strategies over that capability set, which we pose as a general DRL problem rather than per-sample optimization.

Adversarial Training. Despite a long history of proposed defenses against evasion attacks, adversarial training remains one of the few defenses that has consistently demonstrated empirical robustness [28, 49]. Evasion attacks highlight the weakness in a model’s decision-making; by retraining against these AEs the model can become *hardened* or more robust against such attacks. Given training data $D = \{(x_i, y_i)\}_{i=1}^n$, where x_i denotes a malware sample represented in an arbitrary feature space $\mathcal{X}$ and $y_i \in \{1, \dots, Y\}$ is its class label, adversarial training solves the following min-max optimization problem:

$$\min_{\phi} \mathbb{E}_{(x_i, y_i) \sim D} \left[\max_{x'_i \in \Delta(x_i)} \mathcal{L}(\text{clf}_{\phi}(x'_i), y_i) \right], \quad (1)$$

where $\text{clf}_{\phi} : \mathcal{X} \rightarrow \mathbb{R}^Y$ denotes the classifier parameterized by ϕ , $\mathcal{L}$ is the training loss, and $\Delta(x_i)$ defines the set of admissible perturbations for sample x_i . In the malware domain, $\Delta(x_i)$ typically consists of functionality-preserving modifications that satisfy application-specific constraints. The inner maximization seeks a perturbation that maximizes the classifier loss within the admissible perturbation set, while the outer minimization updates the model parameters to minimize the expected adversarial loss, typically using stochastic gradient descent.

2.3 Deep Reinforcement Learning

Fundamentally, reinforcement learning (RL) problems learn optimal policies through environmental interactions formalized as Markov Decision Processes (MDPs). MDPs are defined by the tuple $(\mathcal{S}, \mathcal{A}, \mathcal{R}, \mathcal{T}, \gamma)$, consisting of: a state space $\mathcal{S}$, action space $\mathcal{A}$, reward function $\mathcal{R} : \mathcal{S} \times \mathcal{A} \rightarrow \mathbb{R}$, transition function $\mathcal{T} : \mathcal{S} \times \mathcal{A} \rightarrow \Delta(\mathcal{S})$ (where $\Delta(\mathcal{S})$ denotes probability distributions over states), and discount factor $\gamma \in [0, 1]$ [5, 40, 70]. An RL ‘agent’ observes a state s_t , selects an action a_t according to the policy π , then receives a reward r_t , and transitions to the next state s_{t+1} . The agent then learns a policy that maximizes the expected cumulative discounted reward: $\mathbb{E}[\sum_{t=0}^{\infty} \gamma^t r_t]$.

Proximal Policy Optimization (PPO). PPO [66], one of the most widely used DRL approaches, is an actor-critic method which parametrizes the policy π (actor) alongside the state-value function $V(s_t)$ (critic) with neural networks and opti-

mizes a combined objective:

$$\mathcal{L}^{\text{PPO}}(\theta) = -\mathcal{L}^{\text{P}}(\theta) + c_v \mathcal{L}^{\text{V}}(\theta) - c_e \mathcal{L}^{\text{E}}(\theta). \quad (2)$$

where $\mathcal{L}^{\text{P}}$ is the clipped surrogate objective, c_v is the value coefficient, $\mathcal{L}^{\text{V}}$ is the clipped value loss, c_e is the entropy coefficient, and $\mathcal{L}^{\text{E}}$ is the entropy bonus. Further breakdown of PPO can be found in Appendix B.

Action Masking. In an environment only a subset of the action space may be applicable in a given state, as in problem-space evasion where capabilities may conflict with one another or add nothing new to the current sample. Action masking handles this by masking out the logits of inapplicable actions before the softmax, so that they receive near zero probability and are never sampled. Therefore, this improves the learning efficiency of DRL in tasks with large and conditionally applicable action spaces, while maintaining valid policy-gradient updates [38].

Hierarchical Policies. Hierarchical DRL [42] splits a policy across different levels of abstraction, where a higher-level policy decides what to do next and a lower-level policy decides how to do it. Hierarchical DRL has been shown to improve the performance and tractability of learning in security problems [29–32].

DRL for Cybersecurity. DRL having been used to achieve impressive performance in numerous cybersecurity tasks [1, 29, 31, 32, 36, 45, 51, 54, 71, 74]. However, recent work has raised the common pitfalls of DRL for security research [50]; we therefore follow these best practices to ensure effective demonstration of our modeling, training, evaluation, and deployment assumptions.

3 REPLICANT Framework

This section describes the REPLICANT framework, which formulates problem-space evasion as an MDP and uses hierarchical PPO to learn an attack policy. Our formulation treats the set of available problem-space modifications as an abstract *capability set*, where each element has an observable effect on the feature representation used by the attacker. Throughout our experiments, we use Android gadget transplantation following [10, 19, 59, 78] as the concrete instantiation of the capability set. Notably, our MDP formulation is general and independent of the capability set or the underlying malware detector, thus applicable to any domain with problem-space transformations that have observable effects to the attacker; this general property of RL-based attacks has also been formalized in [73]. Subsection 3.1 explicitly describes our threat model, Subsection 3.2 defines our environment (MDP), and Subsection 3.3 presents our agent.

3.1 Threat Model

Attacker Goal. The goal of the attacker is to violate the *integrity* of the system by modifying malware to be classified

as malware while preserving its malicious behavior. Furthermore, in the process of achieving this goal, the attack aims to minimize the number of both malware modifications and target queries.

Attacker Capabilities. The attacker has a *capability set*: a finite collection of modifications that can be applied to a malware sample while preserving its behavior, each with an observable effect on the feature representation used by the attacker. Throughout this paper we instantiate the capability set with *gadgets*, self-contained code fragments harvested from benign applications and transplanted into the malware sample, following [10, 19, 59, 78].

Attacker Knowledge. This paper considers two levels of attacker knowledge: black-box used in Sections 5.1–5.2 and white-box used in Sections 5.3–5.5. In the black-box setting, the attacker has no explicit knowledge of the target classifier $\text{clf}_{\text{target}}$ and receives only its predicted label (i.e., either benign or malicious), rather than a confidence score. To learn an evasion policy, the attacker instead uses a *surrogate* classifier $\text{clf}_{\text{surrogate}}$ created by themselves or others, which is trained on distinctly different data from the target. Therefore, the surrogate may also differ from the target in both classifier architecture or feature space, which we evaluate in Sections 5.1–5.2. In the white-box setting, the attacker has unrestricted access to the target and thus may use its confidence scores and feature-space representation. We adopt the white-box threat model for the AT experiments in Sections 5.3–5.5 for the following reasons. First, a defender hardening their own model has complete access to it and thus would use the strongest realistic attacker available to them. Second, isolating the robustness gained from AT is best measured using white-box attacks as adding black-box constraints conflates robustness with the difficulty of finding an evasive strategy without access to the target.

Attacker Parity. To fairly compare attacks, we evaluate prior attack baselines with the same capability set and threat model as REPLICANT. In the black-box attack settings, all privileged information is drawn from the surrogate, and the target only provides predicted labels when queried. In the white-box settings used for AT, the attackers have direct access to the confidence scores of, and no limits on the interactions with, the target. As mentioned in Section 1, by eliminating the confounding factor of differing capability sets, this allows our evaluation to isolate the performance differences between attack strategies.

3.2 REPLICANT MDP

State Space. The state $s_t \in \mathcal{X}$ is the current representation of the (partially modified) sample after t steps, in the feature space $\mathcal{X}$ used by the attacker, with s_0 being the original representation of the malware.

Action Space. The hierarchical action space of REPLICANT is split across two separate policies: the higher-level *query*

policy and the lower-level *modify* policy. Based on s_t , REPLICANT first selects a *query* action, $q_t \in \{\text{SUBMIT}, \text{MODIFY}\}$. If $q_t = \text{SUBMIT}$ then the classifier is queried, $\text{clf}(s_t) \in \{0, 1\}$, and no capabilities are applied. If $q_t = \text{MODIFY}$, then the modify policy selects a capability to apply to the malware sample and does not query the classifier. The *modify* action $m_t \in \{1, \dots, N\}$ selects a capability $c_{m_t} : X \rightarrow X$ from the capability set $C = \{c_1, \dots, c_N\}$. *Action masking* removes, prior to selection, any modify action whose capability either: (i) adds no new features (a *no-op*), or (ii) would *conflict* in the problem space, covered in Appendix C. Furthermore, masking is also applied to the query policy: (i) MODIFY is masked every p steps during training ($p = 10$), forcing periodic submits, to ensure the agent receives feedback from the classifier throughout training episodes; and (ii) SUBMIT is masked until at least one modification has occurred since the last query.

Transition Function. The state transitions are driven by the modify actions (m_t), as each applied capability modifies the underlying sample and, therefore, updates its feature representation. Since each capability corresponds to a concrete problem-space modification whose effect on the feature space is known in advance, we can model and evaluate the MDP in the feature space while maintaining the problem-space realizability of every transition. The episode terminates when the step count reaches the horizon H (max steps per episode) or a query evades the classifier. Therefore, the full transition function is as follows:

$$T(s_t, q_t, m_t) = \begin{cases} \text{terminal} & \text{if } q_t = \text{SUBMIT} \wedge \text{clf}(s_t) = 0, \\ \text{terminal} & \text{if } t = H, \\ c_{m_t}(s_t) & \text{if } q_t = \text{MODIFY}, \\ s_t & \text{else.} \end{cases} \quad (3)$$

Reward Function. The reward function is as follows:

$$R(s_t, q_t, m_t) = \begin{cases} R_{\text{success}} & \text{if } q_t = \text{SUBMIT} \wedge \text{clf}(s_t) = 0, \\ R_{\text{detected}} & \text{if } q_t = \text{SUBMIT} \wedge \text{clf}(s_t) = 1, \\ R_{\text{modify}}(s_t, c_{m_t}) & \text{if } q_t = \text{MODIFY}. \end{cases} \quad (4)$$

where $R_{\text{success}} \gg 0$ rewards successful evasion, $R_{\text{detected}} \leq 0$ penalizes detection, and $R_{\text{modify}}(s_t, c_{m_t}) < 0$ penalizes each capability applied. The relative magnitudes of these three terms determine the trade-offs between modification and query efficiency learned by the agent. In this paper, we use:

$$R_{\text{success}} = H, \quad R_{\text{detected}} = -1, \quad R_{\text{modify}}(s_t, c_{m_t}) = -1. \quad (5)$$

These values were chosen to: (i) ensure every successful episode has a positive return, since the total penalties over an episode of at most H steps cannot surpass R_{success} ; and (ii) incentivize an efficient but balanced use of both modifications and queries. During training, as previously mentioned, the query policy is masked to force periodic submits (*PS*). We scale the reward of these forced submits by $\lambda_{PS} \in [0, 1]$, giving the training reward:

$$R(s_t, q_t, m_t) = \begin{cases} \lambda_{PS} R(s_t, q_t, m_t) & \text{if } t \equiv 0 \pmod{p}, \\ R(s_t, q_t, m_t) & \text{otherwise.} \end{cases} \quad (6)$$

We set $\lambda_{PS} = 0$ for two reasons. First, early in training the agent is usually detected when it queries and can learn to avoid querying altogether; making these periodic queries zero-cost encourages it to explore querying. Second, once the agent is more capable, $\lambda_{PS} = 0$ encourages the agent to voluntarily submit early to maximize reward.

3.3 REPLICANT Agent

The general architecture and training pipeline that is used to make the REPLICANT agent is as follows, with the specific hyperparameters used in our experiments reported in Appendix C.1. A shared MLP encoder feeds three heads, each adding one further layer before its output: a *query* head over $\{\text{SUBMIT}, \text{MODIFY}\}$, a masked *modify* head over the capability set C , and a *critic* head estimating state value $V(s_t)$. Training uses PPO [66], with the query policy loss applied at every step; the modify policy loss applied *only* on MODIFY steps, relying on the evasion reward being propagated through advantage estimation; and the critic is shared across both. The query and modify heads share a common entropy coefficient, encouraging exploration over both *when* to query and *what* to add. Each update collects a batch of parallel episodes using complete-episode rollouts rather than a fixed number of steps, as the positive reward only arrives on episode termination. Because training yields a *policy* π_θ rather than a fixed AE, what REPLICANT learns is not bound to a single input or target: the same π_θ can be used to evade malware it has never seen and, as Section 5.2 shows, transfers to classifiers and feature spaces it was never trained against.

REPLICANT_{WB}. We also produce a white-box variant of REPLICANT (REPLICANT_{WB}) for use in AT and the robustness evaluations of the hardened targets in Sections 5.3-5.5. Architecturally, REPLICANT_{WB} drops the query head and submits after every modification, since query efficiency is not required in the white-box setting; it also uses the confidence score of the target, $\text{clf}_{\text{score}}$, for rewards. More specifically, the white-box rewards are as follows:

$$R_{\text{WB}}(s_t, c_{m_t}) = \lambda_{\text{WB}} (\text{clf}_{\text{score}}(s_t) - \text{clf}_{\text{score}}(s_{t+1})) \quad (7)$$

which rewards the reduction in the malware confidence of the target classifier, scaled by the hyperparameter λ_{WB} . Since confidence deltas can be small, we scale them by $\lambda_{\text{WB}} = 5$ for all targets. Empirically, this gives more signal to per-step rewards in training, allowing for faster convergence during training [7]. Beyond architecture and reward, the rest of the REPLICANT formulation remains unchanged.

AT-REPLICANT. Our pipeline for Adversarial Training (AT) with REPLICANT (AT-REPLICANT), used in the Sections 5.3-5.5, is as follows. We extend the 15-round AT methodology of [73], where each round of AT-REPLICANT trains a fresh REPLICANT_{WB} policy against the classifier being hardened and collects every AE generated over the course of that training run; the unique AEs collected are added to the training

set of the classifier for retraining before the next round. As the classifier becomes harder to evade with each round [73], a fixed training budget yields progressively fewer AEs, so we increase the number of policy updates as AT progresses. Empirically the number of new AEs collapses after five rounds under a fixed budget, whereas doubling the policy updates of REPLICANT_{WB} every five rounds maintains AE production across all 15 rounds (details shown in Appendix Table 12). We therefore adopt this schedule as our default in all AT-REPLICANT experiments. Simultaneously collecting AEs throughout training exposes the classifier to many distinct variants of every malware sample, unlike collection from an already-converged policy or via greedy composition. This diversity forces the classifier to adapt to a broader region of problem-space perturbations rather than overfitting to a single evasive strategy.

RAL. Finally, for performance and robustness under temporal drift (Section 5.5), we propose RAL, which extends AL by running one AT-REPLICANT round on the malware collected each AL period and adds the resulting AEs to the AL update set.

4 Experimental Setup

Dataset. In our experiments we use the *Hypercube* [18] Android malware dataset, spanning 224,965 samples from 2021–2024, constructed to follow the current best practices for unbiased dataset creation: sampling from a single market (Google Play) using publication timestamps, at a statistically representative size, with a realistic malware distribution of 10% and a VirusTotal Threshold of two (VTT2). Additionally, we investigate the impact of VTT by also evaluating evasion on a variant of Hypercube sampled at a VTT of four (Hypercube_{VTT4}). We repeat every experiment: (i) over ten random seeds to account for variance [50]; and (ii) over two temporally distinct training periods (2021 & 2022) to avoid bias from temporal luck [18].

Training Sets. For each seed, we perform a random stratified split to produce two equal sized training sets per training year: split *a* trains the surrogate and REPLICANT policies, and split *b* trains the target (e.g., 2021*a*-vs-2021*b* and 2022*a*-vs-2022*b*). To investigate transferability across temporal distributions for the black-box experiments (Sections 5.1–5.2), we also consider surrogate and target pairs across years (e.g., 2021*a*-vs-2022*b* and 2022*a*-vs-2021*b*).¹

Testing Sets. We evaluate attack performance using malware from the year after target training (e.g., 2023 for a 2022*b* target); which realistically mimics evasion by malware authors as they attempt to evade deployed detectors over time. For black-box experiments we consider a one year test period to

keep temporal drift minimal, as drift would otherwise inflate ASR (Appendix Table 8). For the white-box experiments, we extend the test period to two years (e.g., 2023–2024 for a 2022*b* target), as these evaluations measure the robustness gained through AT, which should be assessed over a full deployment period rather than a single year ahead. For each seed and feature space, the evasion test set is the malware that *every* classifier correctly detects ensuring that differences in ASR reflect the attack rather than which malware each classifier happens to detect.

Variance. Following [50], we repeat every experiment over ten random seeds and report the resulting variance through 95% confidence intervals (95% CI) across seeds. Each seed repeats the network initializations, the policy training, the surrogate and target training splits, and, in turn, the test set.

Feature Spaces. We train all classifiers on the Drebin [4], APIGraph [80], and RAMDA [47] feature spaces. For Drebin, we follow the work of [18, 21, 41, 51] and use the top 10k features based on feature-importance via linear model coefficients. For APIGraph, following the original work [80], we use Drebin for the non-API features and their clustering pipeline to enrich the API features. For Ramda, we use the original 379 features as proposed in [47]. In total, the Drebin, APIGraph, and RAMDA feature spaces contain 10,000, 11,912, and 379 features, respectively. We chose these three spaces for their differing sizes and overlap (Section 2.1), which allow us to evaluate transferability across varying degrees of alignment between the surrogate and target feature spaces.

Classifiers. We evaluate against the following seven classifiers: Linear SVM [4], SecSVM [21], Random Forest [57], DeepDrebin [34], RAMDA [47], HCC [16], and DRMD [51]. We chose these seven classifiers because they span a diverse set of design principles, from margin maximization and ensemble voting to reconstruction, contrastive, and reward-weighted losses. Therefore, this diversity allows us to evaluate transferability and performance across a representative set of architectures and optimization objectives in Android malware detection, giving a more generalizable measurement of the attacks considered.

Capability Set. Our capability set comprises gadgets harvested by prior problem-space work [10, 19, 59, 78], together with their feature-space effects we computed. Each gadget affects only a small set of features, so for each feature space we use the subset that changes at least one of its features, resulting in 3,143 for Drebin, 4,804 for APIGraph, and 1,739 for RAMDA. For cross-feature-space attacks, the attacker selects from the capability set applicable in their own feature space, and the target sees the effect of applying those gadgets in its own feature space. As motivated and discussed in Section 3.1, all attacks are performed under the same threat model and capability set for each setting, to ensure reported differences reflect attack strategy rather than access to different capabilities.

¹ In the 2022*a*-vs-2021*b* setting, the surrogate overlaps the 2022 test year, but excluding these overlapping samples changes ASR by < 0.2 percentage points (Appendix Table 11); thus, we report over 2022 for consistency and simplicity of discussion.

Baselines. We compare against three state-of-the-art problem-space Android malware evasion attacks, which all optimize samples individually: (i) *APG* [19, 59], white-box greedy capability selection by score contribution; (ii) *AdvDroidZero* (*ADZ*) [35], gray-box tree search over a perturbation set using model confidence; and, (iii) *EvadeDroid* (*EvD*) [11], gray-box greedy random capability selection that only keeps modifications that reduce target confidence. Following [50], we also evaluate *Rnd*, which uses the REPLICANT framework but selects actions uniformly *at random*, to isolate the performance gains of policy learning. Hyperparameters for the baselines and classifiers can be found in the Appendix C.2-C.4.

RL Design Ablation. To isolate the gains provided by the architecture of our agent and its reward function over prior RL-based work, we compare against five alternative state-of-the-art RL agent designs for malware evasion: (i) *MEME* [63], model-based PPO; (ii) *MAB-Malware* (*MAB*) [69], Thompson-sampling multi-armed bandit; (iii) *MERLIN* (*MRLN*) [60], deep Q-learning (DQN); (iv) *AIMED-RL* (*AIM*) [44], distributional double DQN with NoisyNet exploration and prioritized replay; and (v) *PSP-Mal* (*PSP*) [79], dueling double DQN with Shapley-guided prioritized experience replay. As each of these five RL-based attacks were originally proposed for Windows PE malware evasion, we adapted them to Android by modifying them to use our environment, threat model, and capability set.

Metrics. We report ASR, specifically the percentage of malware that evaded detection at a fixed per sample budget of twenty queries, as our primary metric. We also report the average number of queries per sample (AvgQ) as a secondary metric for attacks to measure query-efficiency. We use the F_1 as our primary clean performance metric, using the Area Under Time (AUT) to measure the F_1 over time ($AUT(F_1)$) following [41, 58]. Furthermore, since metrics from a single training period are subject to temporal luck [18], we report ASR and $AUT(F_1)$ ($A-AUT(F_1)$) [18] averaged over both training periods (2021*b* and 2022*b*) unless otherwise specified (e.g., cross period evaluations in Sections 5.1-5.2).

Statistical Testing & Table Reporting. For statistical testing, we use the Wilcoxon signed-ranks test, following [23]. For reporting statistical significance in tables, the best result and any other value of statistical equivalence (at $p < 0.01$) are reported in *bold*. The statistically second best values are reported in *italics*. For *bold* values, the superscript denotes the statistical significance over the *italics* value (** $p < 0.01$, *** $p < 0.001$). Each result is reported as the mean $\pm$ 95% confidence interval to capture variance across seeds.

5 Evaluation

Our evaluation is organized across five research questions to analyze the performance of REPLICANT in different scenarios. Through these scenarios and comparisons with multiple

baselines, our evaluation demonstrates REPLICANT as a state-of-the-art evasion strategy.

- RQ1. *Black-Box Evasion.*** Is REPLICANT the most effective and query-efficient black-box evasion attack when compared with prior problem-space attacks?
- RQ2. *Policy Transfer.*** How do architectural, representational, and temporal differences affect *policy* transfer?
- RQ3. *Adversarial Training.*** Does AT-REPLICANT produce classifiers that are more robust to unseen attackers?
- RQ4. *Capability Drift.*** Does the robustness of AT generalize to problem-space capabilities held out of training?
- RQ5. *Temporal Drift.*** Can a classifier retain the robustness of AT while adapting to temporal drift with AL?

5.1 Black-Box Evasion

This section establishes REPLICANT as a state-of-the-art, query-efficient black-box evasion attack. We first present its query efficiency in the *matched setting*, where the surrogate and target share a classifier, feature space, and training period, differing only in their training data (42 combinations per attacker). Then we show it is the strongest attack across *all* surrogate/target settings, spanning seven classifiers, three feature spaces, and two training periods for both the surrogate and target (1,764 combinations per attacker). Lastly, we confirm that these conclusions are robust to both VTT and the distribution from which the test set is drawn.

Matched Setting. In the *matched* setting, the surrogate and target classifiers share an architecture and feature space but are trained on separate training sets (Section 4); with no difference between architecture or feature space, this setting represents the best-case scenario for a black-box attacker. The matched section of Table 1 reports the mean ASR for each attacker and target classifier, averaged over feature spaces and seeds. REPLICANT achieves a mean ASR of 96.6% using an average of 3.6 queries per sample. Thus outperforming every baseline in this setting, with minimal gap between surrogate and target, which is more closely aligned with the threat model of prior attacks. The strongest baseline, APG, reaches only 77.7% while the ADZ, EvD, and random baselines sit at 61.5%–69.7%. APG is statistically tied with REPLICANT on SVM, SecSVM and DeepDrebin, where ranking capabilities by their contribution to the surrogate decision function most closely aligns with the target boundary. The gap is largest on the RL-based DRMD, where APG collapses to 25.2% against the 90.2% of REPLICANT, followed by RAMDA and RF (35.4 & 27.6 points), with every other baseline statistically beaten on *every* target. By feature space, the mean ASR of REPLICANT is 98.8% for Drebin, 98.3% for APIGraph, and 92.5% for the smaller 379-feature RAMDA space.

Table 1: **Evasion Results**, attacker comparison against Android evasion baselines for both the *matched* and *all* settings, reporting mean ASR and AvgQ for both.

Matched	REPLICANT	APG	ADZ	EvD	Rnd
SVM	99.1 ^{***} _{±1.5}	99.1 ^{***} _{±1.5}	73.5 _{±3.6}	84.0 _{±2.8}	74.2 _{±3.7}
SecSVM	98.2 ^{***} _{±1.0}	98.7 ^{***} _{±0.9}	53.6 _{±4.0}	73.5 _{±1.9}	54.3 _{±4.3}
RF	93.3 ^{***} _{±1.7}	65.8 _{±3.2}	72.1 _{±2.1}	69.9 _{±2.3}	70.7 _{±2.4}
DeepDrebin	96.5 ^{***} _{±2.1}	94.5 ^{***} _{±2.3}	56.0 _{±2.0}	69.1 _{±2.6}	57.9 _{±2.1}
RAMDA	99.9 ^{***} _{±0.1}	64.5 _{±3.6}	81.3 _{±3.8}	72.0 _{±3.3}	82.6 _{±2.8}
HCC	98.7 ^{***} _{±0.9}	96.1 _{±2.0}	79.2 _{±2.5}	85.2 _{±2.0}	81.6 _{±3.0}
DRMD	90.2 ^{***} _{±2.7}	25.2 _{±2.3}	14.5 _{±1.6}	34.0 _{±2.4}	16.8 _{±1.9}
ASR	96.6 ^{***} _{±0.7}	77.7 _{±0.8}	61.5 _{±1.1}	69.7 _{±1.1}	62.6 _{±2.0}
AvgQ	3.6 ^{***} _{±0.3}	6.5 _{±0.2}	10.6 _{±0.2}	9.9 _{±0.2}	10.0 _{±0.2}
All Settings	REPLICANT	APG	ADZ	EvD	Rnd
ASR	78.8 ^{***} _{±1.2}	65.2 _{±0.9}	61.5 _{±1.2}	56.6 _{±0.9}	59.4 _{±1.1}
AvgQ	7.4 ^{***} _{±0.2}	9.3 _{±0.2}	10.6 _{±0.2}	11.7 _{±0.2}	10.4 _{±0.2}

All Settings. In practice, an attacker rarely has a surrogate that matches the target, so we now evaluate REPLICANT across *all* 1,764 surrogate/target combinations, in which the surrogate and target may differ in classifier, feature space, training period, or all axes. The “all settings” section of Table 1 reports the mean ASR and AvgQ across these settings, and Figure 1 plots the full ASR per query curve. REPLICANT achieves the highest evasion rate (78.8% ASR), beating every Android baseline by 13.6–22.2 ASR points. One key advantage of REPLICANT is that it is truly black-box by design, learning only from binary decisions, whereas attacks such as ADZ and EvD rely on access to target confidence scores, a strong and less realistic assumption. Since the baselines use changes in confidence to steer capability selection, as the surrogate diverges from the target, its confidence degrades as a proxy for the decision boundary of the target, a similar failure mode to that of sample transfer evasion as found by [22]. REPLICANT instead learns a *policy* over the malware used to train the surrogate, thereby capturing the general task of evasion rather than the surrogate confidence topology. Therefore, we demonstrate that task-level knowledge transfers across settings more reliably than overfitting to confidence signals that the baselines rely on.

Query-Efficiency. At a query budget of 20, Table 1 shows that REPLICANT is also the most query-efficient attacker by AvgQ, spending the fewest average queries per sample of any attack: 3.6 in the matched setting and 7.4 across all settings versus the 6.5 and 9.3 of APG, the Android strongest baseline. With Figure 1 demonstrating that REPLICANT yields the highest ASR per target query out of all attacks considered.

Policy Ablation. Rnd uses the same MDP as REPLICANT, however, it selects *when* to query and *which* applicable capability to add at random. Therefore, by evaluating Rnd, we can isolate the performance gain of the policy learned by REPLICANT from the base performance of the capability set and action masking. Figure 1 illustrates that across all settings,

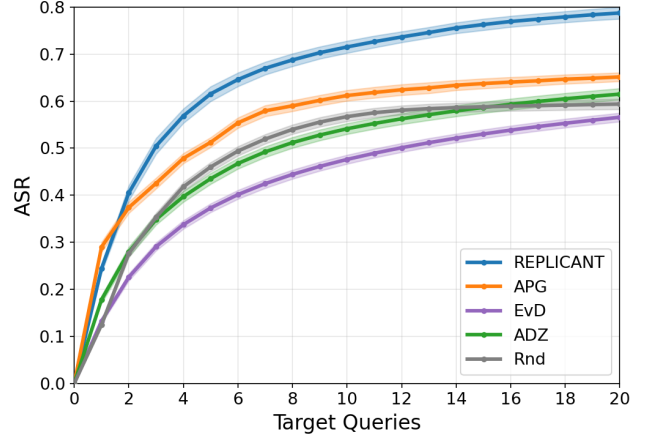


Figure 1: **Evasion Curves**, attack efficiency across all 1,764 surrogate/target combinations and ten seeds. REPLICANT outperforms every baseline with the highest evasion rate per query.

Rnd matches the performance of both ADZ and EvD, while approaching the performance of APG at a budget of twenty queries. This demonstrates that: (i) the environment design of REPLICANT provides performance on par with prior attacks under our threat model; (ii) the performance gains over prior attacks are the result of our learned policy; and (iii) it exposes the weakness of relying on surrogate confidence scores for black-box attacks.

RL Design Ablation. Although Android problem-space attacks are dominated by per-sample optimization, policy-based evasion strategies are more prevalent in the neighboring domain of Windows PE problem-space evasion. Therefore, to isolate the gains of our architecture and reward function, we compare against five alternative RL agent designs adapted to Android by using our environment, threat model, and capability set. We find that in comparison to prior agent designs, REPLICANT improves the mean ASR by 5.6–22.2 points across *all* 1,764 settings, using 1.1–5.2 less queries on average. Full results for both the *matched* and *all* settings can be found in Appendix F.

Datasets & VTT. Our main results use the canonical Hypercube dataset, which samples the distribution and labels applications using VirusTotal threshold of 2 (VTT2). To confirm our results are not an artifact of this threshold, we re-run the black-box experiments on a variant of Hypercube created for VTT4 (Hypercube_{VTT4}). As a result of our threat model relying on surrogates for attack optimization and target agreement for test sets, the quality of data used to build both models is intrinsically linked with our evaluation. Since VTT4 creates a higher standard for samples to be labeled as malware, it simplifies the detection task, dropping misclassification rates for 2022 malware from 63.8% to 46.9%. Thus

VTT4 has a two-fold effect on our evaluation that makes it more favorable for the attacker: (i) it provides a larger test set as more malware are detected by all targets for a given seed and (ii) it produces more capable surrogates that provide a better proxy for the targets. These two factors result in a higher mean ASR across all attacks; REPLICANT rises from 78.8% (VTT2) to 94.1% (VTT4), remaining the dominant attacker (12.6% better than the best baseline). The full results for VTT4 are presented in Appendix Table 7. Therefore, since using VTT2 follows current best practice [18] and it is the more conservative setting for attack performance, our main results give a realistic measure of attack efficacy that is not inflated by higher labeling thresholds.

Evaluation Periods. The results discussed so far reflect the realistic ASR against a deployed target, by evaluating the attacks on malware from the year following the target’s training period (e.g., 2022 malware for a 2021*b* target). However, to confirm the attacks are also effective in-distribution, we additionally test on the malware from the surrogate split of each target’s training year (e.g., 2021*a* malware for a 2021*b* target, and 2022*a* for a 2022*b* target). The attack remains effective, with only a minor decline in performance; the mean ASR of REPLICANT on in-distribution malware is 70.0% compared to the 78.7% of the main temporally withheld results. Furthermore, when testing on malware from two and three years after the training periods, the mean ASR rises to 89.4% and 95.4%, respectively. The full breakdown of results for each testing period relative to the training period is reported in Appendix Table 8.

RQ1: REPLICANT is the most effective and query-efficient black-box attack across all 1,764 settings, evading 78.8% of malware within twenty queries. Thus beating every Android baseline by 13.6–22.2 points (an improvement of 20.9%–39.2%).

5.2 Transferring Policies

Having established REPLICANT as the strongest attacker in Section 5.1, it is important to investigate how different surrogate-to-target gaps affect transferability. Thus, we now provide a more detailed break down of the results from *all settings* for REPLICANT in Table 2. Specifically, we consider four transferability axes: the temporal gap (when training periods differ), the architecture gap (when classifiers differ), the representation gap (when feature spaces differ), and the combined gap (when all differ). Across these four axes, we analyze both *Policy Transfer Evasion (PTE)*, where the policy learned by REPLICANT is deployed against the target, as it was done in Section 5.1; and *Sample Transfer Evasion (STE)*, where REPLICANT evades the surrogate, and those AEs are applied directly to the target. Therefore, both attacks use identical policies, capabilities, and surrogates; they only differ in

Table 2: **Transferability Results**, Policy Transfer Evasion (PTE) versus Sample Transfer Evasion (STE) for REPLICANT across the *matched* setting and four axes of transferability within *all* settings.

Transfer Axes	PTE		
	ASR	AvgQ	STE
Matched	96.6 ^{***} _{±0.7}	3.6 _{±0.3}	59.4 _{±4.3}
Temporal	96.6 ^{***} _{±0.6}	3.6 _{±0.3}	59.4 _{±4.4}
Architecture	87.4 ^{***} _{±1.1}	5.8 _{±0.3}	44.7 _{±1.8}
Representation	78.8 ^{***} _{±1.3}	7.6 _{±0.2}	42.5 _{±2.8}
Combined	73.0 ^{***} _{±1.5}	8.5 _{±0.2}	41.3 _{±1.9}
All Settings	78.8 ^{***} _{±1.2}	7.4 _{±0.2}	43.3 _{±1.8}

whether the learned policy is employed as an active attacker or used to pre-compute AEs, as done in classical transfer attacks [22]. Table 2 compares PTE and STE across the four axes we consider, and Figure 2 plots their corresponding ASR curves against target queries.

Temporal Gap. Matching the classifier and feature space but training the surrogate and target in *different* periods (Figure 2, purple; per-period-pair breakdown in Appendix Figure 5), PTE retains a mean ASR of 96.6%, statistically indistinguishable from the matched setting. Therefore, the learned policy is effectively invariant to the temporal gap; the only appreciable difference is between 2021*b* and 2022*b* targets as seen in Appendix Figure 5, which is a result of temporal luck [18] rather than the surrogate-target gap.

Architecture Gap. When the surrogate and target share the same feature space but differ in architecture (Figure 2, green; per-target breakdown in Appendix Figure 6), transfer remains strong: PTE evades 87.4% of malware within twenty queries against 44.7% for STE, and overtakes STE within roughly two queries. Given a shared representation, the learned effect that each modify action has on the feature space still holds for the target; the agent, therefore, retains an accurate model of how its capabilities change a sample. The differing architecture only relocates the boundary it must cross and the magnitude of the capability impact. The architecture gap is thus paid foremost in queries: ASR rises slowly against the targets whose boundaries differ most from the surrogate, most notably DRMD as shown in Appendix Figure 6, the only RL-trained detector, whose categorically different training regime makes its boundary the least similar to the others.

Representation Gap. Keeping the architecture fixed while moving the surrogate and target into different feature spaces (Figure 2, orange; per-space-pair breakdown in Appendix Figure 7) lowers ASR to 78.8%, still far above the 42.5% of sample transfer. The performance decay concentrates on pairs involving RAMDA especially when it is used as the surrogate as can be seen in Appendix Figure 7. A policy trained on

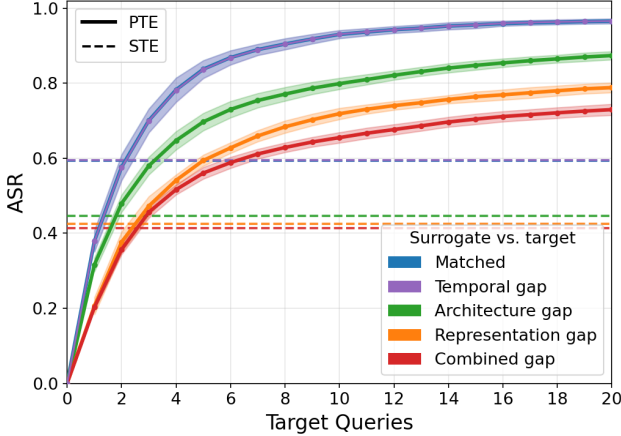


Figure 2: **Transferability Curves**, Policy Transfer Evasion (PTE) versus Sample Transfer Evasion (STE) for REPLICANT. Solid curves plot PTE over queries and the dashed lines display the ASR of STE.

RAMDA, the smallest feature space, and deployed against a richer target space has only learned capabilities that affect a small fraction of the target representation and must therefore rely either on that sub-region to influence the decision of the target or on incidental side-effects its capabilities produce elsewhere in the larger representation. Conversely, transferring an attack into a smaller representation, such as RAMDA, can render many of its modifications invisible to the target, as they are not captured by the representation of the target. This reduces the number of capabilities that have a tangible affect on the target, inducing a lower ASR ceiling than the architecture gap, where the shared feature space leaves the full capability set intact. Therefore, this reduction in ASR reflects an underlying property of the representation gap rather than any intrinsic robustness of RAMDA, as shown by the high ASR per query of RAMDA→RAMDA in Appendix Figure 7. **Combined Gap.** This is the hardest regime, where the surrogate differs from the target in architecture, feature space, and training period (Figure 2, red; per-target breakdown in Appendix Figure 8). The costs of each transferability gap now compound: the policy pays in queries to push towards the shifted boundary and in expressiveness to compose capabilities in a representation it was not trained on, lowering the ASR of PTE to 73.0%, still far above the 41.4% of STE. Their combination also widens the spread across targets in Figure 8: DRMD is the hardest target to evade, which is further compounded by the representation gap to produce the slowest per-query ASR rise. Even so, PTE reaches an ASR of 41.1% against it, whereas STE reaches only 4.2%.

Policy over Sample Transfer. A transferred *sample* is optimized to pass the decision boundary of the surrogate and relies on the alignment of decision boundaries. A transferred

Table 3: **AT Results**, robustness comparison between AT-REPLICANT and AT-APG against both the REPLICANT_{WB} and APG_{WB} attackers. Results report mean ASR.

Classifier	REPLICANT _{WB}		APG _{WB}	
	AT-REPLICANT	AT-APG	AT-REPLICANT	AT-APG
SVM	9.8 ^{±0.6} *	99.9 ^{±0.1}	10.1 ^{±0.9} *	100.0 ^{±0.0}
SecSVM	8.9 ^{±2.8} *	48.4 ^{±4.2}	9.3 ^{±2.8} *	49.3 ^{±4.3}
RF	1.9 ^{±0.3} *	77.4 ^{±1.9}	3.7 ^{±0.3} *	7.8 ^{±0.7}
DeepDrebin	7.2 ^{±2.7} *	12.1 ^{±2.8}	17.2 ^{±4.5}	13.6 ^{±3.3}
RAMDA	16.0 ^{±5.6} *	86.9 ^{±6.3}	14.0 ^{±1.4}	19.6 ^{±4.5}
HCC	18.2 ^{±4.0} *	25.7 ^{±4.5}	51.2 ^{±5.6}	46.6 ^{±4.6}
DRMD	7.6 ^{±1.6} *	86.4 ^{±1.2}	8.8 ^{±1.8} *	12.2 ^{±1.8}
Mean	9.9 ^{±1.3} *	62.4 ^{±1.8}	16.3 ^{±1.2} *	35.6 ^{±1.1}

policy instead encodes a *distribution over actions* conditioned on the current representation of the sample. This provides PTE with a distinct advantage that is exactly where STE fails: as surrogate and target diverge, misaligned boundaries cause sample transfer to decay, while an adaptive policy re-queries until the decision boundary is crossed. Averaged over all settings, PTE reaches 78.8% ASR against 43.3% for STE, and overtakes the ASR of STE within three queries on average. Therefore, when the surrogate and target agree on nothing but the distribution from which their training data was drawn, what transfers best is the learning of *how to evade*, not specific evasive samples.

RQ2: As the gap between the surrogate and target grows, the ASR of REPLICANT degrades gradually (96.6%→73.0%). Across all settings, PTE reaches a mean ASR of 78.8% compared to the 43.3% of STE (an improvement of 82.0%). Demonstrating that policies consistently transfer across both architecture and representation, while AEs do not.

5.3 Adversarial Training

The robustness gained from adversarial training depends on the quality of the attacker [49], so we harden with the strongest attacker from each attack type (i.e., policy-based and per-sample optimization). Therefore, motivated by the results of Section 5.1, we use REPLICANT for learned policies and APG for per-sample optimization to provide the most informative comparison. Since AT relies on successful evasions and classifier robustness is best evaluated under the strongest threat model [13], we conduct all experiments in this section using *white-box* attacks (_{WB}). As we are not considering transferability, and evasion rates are similar between the feature spaces in the matched setting (Section 5.1), we focus this analysis on the Drebin feature space because it is the most widely used representation [4]. AT-REPLICANT and AT-APG follow the pipeline presented in Section 3.3, however, AT-APG col-

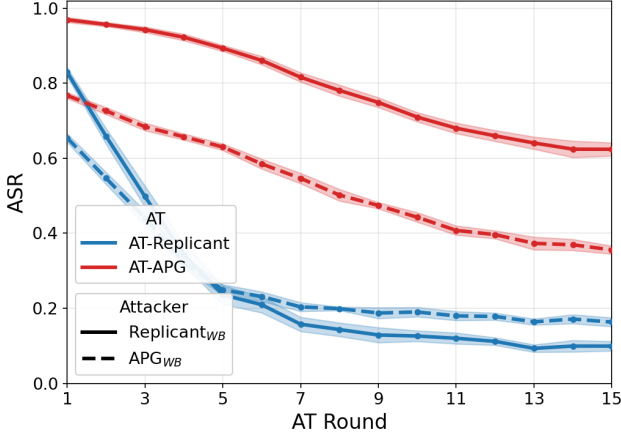


Figure 3: **AT Curves**, ASR across both attackers and AT pipelines for each of the 15 AT rounds. The colors denote the AT pipeline and line style denotes the attacker.

lects AEs during its per-sample rollouts as it does not have a training phase.

Robustness Evaluation. We evaluate each classifier trained by both AT pipelines against both REPLICANT_{WB} and APG_{WB} attacks. Table 3 reports the ASR of the white-box attackers against both AT pipelines after 15 rounds and Figure 3 plots the ASR across rounds. After 15 rounds, AT-REPLICANT reduces the mean ASR to 9.9% and 16.3% for REPLICANT_{WB} and APG_{WB} , respectively. Therefore, AT-REPLICANT produces classifiers that are robust against both the attack it was trained on and an unseen attacker. Conversely, AT-APG primarily reduces the mean ASR of APG_{WB} (35.6%) while remaining vulnerable to REPLICANT_{WB} (62.4%). As shown in Figure 3, this asymmetry holds throughout training: both attackers’ ASR decay similarly across subsequent rounds of AT-REPLICANT, while the performance of REPLICANT_{WB} reduces more slowly than APG_{WB} across successive rounds of AT-APG.

AT-REPLICANT Generalization. APG is greedy and deterministic, thus each round naturally focuses on a small sub-set of capabilities and limits the diversity of AEs produced. As a result, REPLICANT_{WB} learns capability sequences outside from the targeted paths AT-APG trained on, and achieves a mean ASR of 62.4%. Conversely, the robustness learned by AT-REPLICANT generalizes better as it collects diverse AEs during *stochastic policy training*, providing significantly more coverage of attack paths. Therefore, the *coverage* of possible paths modulates how broadly the robustness gained by AT can generalize.

Clean Performance. We also report the clean performance (mean first month F_1 and A-AUT(F_1)) of the classifiers produced by both AT pipelines in Appendix Table 4. AT-REPLICANT has a more adverse effect than AT-APG to the

Table 4: **Clean Performance**, for the base, AT-REPLICANT, and AT-APG trained classifiers over the first evaluation month (F_1) and A-AUT(F_1).

Classifier	First-Month F_1			3-Year A-AUT(F_1)		
	Base	AT-REPLICANT	AT-APG	Base	AT-REPLICANT	AT-APG
SVM	81.7 $^{**}_{\pm 0.2}$	73.7 ± 0.5	80.7 ± 0.5	25.8 ± 0.7	25.0 ± 0.5	25.7 ± 0.6
SecSVM	78.7 $^{**}_{\pm 0.6}$	60.8 ± 3.2	68.3 ± 3.6	24.7 ± 0.6	32.2 $^{**}_{\pm 0.8}$	28.9 ± 0.7
RF	83.3 $^{**}_{\pm 0.3}$	81.8 ± 0.6	84.0 $^{**}_{\pm 0.4}$	23.5 ± 0.4	31.8 $^{**}_{\pm 0.3}$	25.0 ± 0.5
DeepDrebin	79.4 ± 1.0	80.1 $^{**}_{\pm 0.7}$	81.3 $^{**}_{\pm 0.4}$	24.7 ± 1.5	29.0 $^{**}_{\pm 1.1}$	28.4 $^{**}_{\pm 0.7}$
RAMDA	80.9 ± 0.6	79.6 ± 0.4	77.5 ± 3.3	23.9 ± 1.1	28.5 $^{**}_{\pm 0.9}$	27.9 $^{**}_{\pm 1.1}$
HCC	82.3 ± 0.8	81.7 ± 0.6	77.6 ± 3.8	26.3 ± 1.1	26.3 ± 1.1	25.1 ± 1.4
DRMD	76.8 $^{**}_{\pm 1.3}$	65.9 ± 1.8	71.3 ± 1.4	36.0 $^{**}_{\pm 0.5}$	33.8 ± 0.8	33.4 ± 0.4
Mean	80.4 $^{**}_{\pm 0.6}$	74.8 ± 1.9	77.3 ± 1.5	26.7 ± 1.0	29.5 $^{**}_{\pm 0.8}$	27.8 ± 0.7

initial F_1 performance in the first test month (mean F_1 drop across classifiers of -5.6 versus -3.1). However, when considering performance-over-time, both AT pipelines increase mean A-AUT(F_1) in four of the seven total classifiers, with AT-REPLICANT hardened classifiers improving mean A-AUT(F_1) by 2.8 compared to the 1.1 gain of AT-APG. Therefore, although AT reduces initial performance, the new malware variants for training created by AT-REPLICANT mildly improve the generalization of most classifiers as samples start to drift over time.

RQ3: AT-REPLICANT provides significantly more robustness to both attackers (9.9%–16.3%) compared to AT-APG, which only reduces mean ASR to 35.6% and 62.4% for APG_{WB} and REPLICANT_{WB} , respectively. This demonstrates that the *diversity* of AEs collected during policy training provides better coverage of the adversarial perturbation space (compared to sample-based optimizations), improving robustness and generalization to an unseen attacker.

5.4 Capability Drift

In this section we test whether the robustness learned by the AT pipelines generalizes to *unseen problem-space capabilities*, which we refer to as capability drift. Therefore, we split the capability set in two: (i) the capability set used by both the AT and the initial attacker; and, (ii) the held-out attacker capabilities used to measure generalization to capability drift. We perform AT and the subsequent robustness evaluation as was done in Section 5.3; however, attackers are evaluated six separate times, starting with the initial capability set, and then progressively adding 10% of the total capabilities back in each subsequent evaluation. Figure 4 plots the ASR as the capability set of the attacker drifts, with capabilities measured as a percentage of the original capability set.

Robustness Decay. When reducing the AT capability set (attacker and defender have the same capabilities), results reflect the findings of Section 5.3: AT-REPLICANT shows robustness against both REPLICANT_{WB} (8.7%) and APG_{WB} (14.6%),

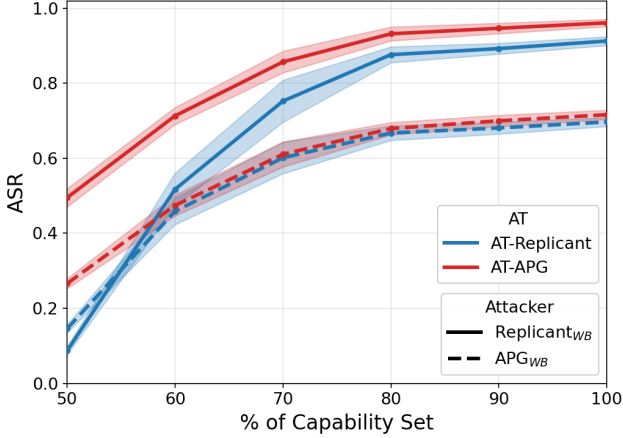


Figure 4: **Capability Drift Curves**, ASR for the attackers as the capability set grows from reduced set (50% of original) to the full capability set.

whereas AT-APG primarily against APG_{WB} (26.6% versus the 49.5% of $REPLICANT_{WB}$). However, as capability drift increases so does the mean ASR of $REPLICANT_{WB}$, with the full capability set reaching 91.3% (AT-REPLICANT) and 96.1% (AT-APG). Therefore, as the attacker set changes, the two AT pipelines demonstrate similar robustness to APG_{WB} ; however, AT-REPLICANT remains *consistently* more robust than AT-APG to the $REPLICANT_{WB}$ attacker at *every* stage of capability drift (mean ASR reduction of -40.8 to -4.9 percentage points). This demonstrates that although AT-REPLICANT generalizes better to capability drift than AT-APG, AT has natural limitations with respect to the capability set it was trained against. Therefore, in practical deployments just as classifiers need AL to adapt to temporal drift, AT must also adapt to capability drift.

RQ4: AT-REPLICANT is more robust than AT-APG at every stage of capability drift; however, the robustness of both pipelines decays as capabilities increase. Demonstrating that although AT-REPLICANT generalizes better across capability drift, AT remains bound to its training capabilities and requires continuous adaptation to stay ahead of evolving threats.

5.5 Temporal Drift

Over time both malware and goodware evolve, without adaptation, the performance of a trained detector decays as new samples drift further from the training distribution. Therefore, in this section, we investigate the impact that temporal drift and its mitigation, Active Learning (AL) [67], have on both

Table 5: **Temporal Drift Results**, clean performance and robustness over time reported as A-AUT(F_1) and A-AUT(ASR), respectively. The WB ($REPLICANT_{WB}$) and BB ($REPLICANT$) attacks are fixed policies from their training period.

Setting	A-AUT(F_1)	A-AUT(ASR)	
		WB	BB
Base	26.7 ± 0.5	99.9 ± 0.0	93.9 ± 0.9
AL	49.8^{***}	98.2 ± 0.2	88.5 ± 0.7
AT	29.5 ± 0.4	0.1^{***}	0.4^{***}
AT&AL	47.9 ± 0.2	19.4 ± 2.1	20.6 ± 1.2
RAL	49.0^{***}	0.6 ± 0.3	0.8^{***}

performance and robustness over time. We compare five different pipelines for the classifiers against fixed REPLICANT attackers (under both the white-box and black-box settings): (i) *Base*, the static classifier from its respective training period; (ii) *AL*, which performs monthly AL updates with 400 samples selected from that period using uncertainty-based selection, following [41, 51, 58]; (iii) *AT*, the AT-REPLICANT pipeline from Section 5.3; (iv) *AT&AL*, the AT-REPLICANT hardened classifiers with AL across the test periods; and, (v) *Robust AL (RAL)*, which we proposed in Section 3.3.

Performance & Robustness over Time. Table 5 demonstrates that drift adaptation ($\uparrow$ A-AUT(F_1)) and adversarial robustness ($\downarrow$ A-AUT(ASR) WB & BB) are largely orthogonal, with no prior strategy improving *both* metrics over the three-year evaluation. The *Base* classifiers perform poorly on both, losing clean performance to drift (26.7) while the fixed attacker policies evade almost completely (99.9% WB, 93.9% BB). *AL* recovers the most clean performance of any configuration (49.8) but, as it never exposes the classifiers to AEs in training, the adaptation only has a minor reduction on attack performance (98.2% WB, 88.5% BB); *AT* conversely suppresses the attackers to near-zero ASR, however, provides only minor robustness to temporal drift (29.5). Combining *AT&AL* improves performance with regards to temporal drift at the cost of adversarial robustness (19.4% WB, 20.6% BB). Finally, only our *RAL*, with its combination of clean and AEs for retraining, improves on both axes, matching the clean performance of *AL* (49.0 versus 49.8) while preserving the adversarial robustness from *AT* (0.6% WB versus 0.1% WB). Therefore, just as *AL* is needed to adapt to temporal drift, *AT* must continually adapt alongside it, as neither *AL* nor *AT* alone is sufficient.

RQ5: Directly applying AL on hardened classifiers improves clean performance at the cost of robustness, however, *RAL* provides performance-over-time while maintaining robustness; matching the performance of *AL* (49.0) and the robustness of *AT* (0.6% WB).

6 Limitations

REPLICANT addresses the *strategy* of problem-space evasion given a fixed capability set, rather than the design of the capability set itself. This scope is deliberate, as conflating newly proposed capability sets and strategies hinders direct comparability and gain attribution [50]. Therefore, in each scenario, we use the same capability set and threat model across all attackers. As a result, the ASRs we report are relative to the capability set and dataset used rather than an absolute upper bound on problem-space evasion, and determining the strongest capability set remains an important open problem, with works such as [65] exploring that line of research. However, REPLICANT is not intrinsically tied to the capabilities used in this work and can be applied to new capability sets as they are developed. For datasets, we only use the Android malware dataset of Hypercube [18]; we made this choice deliberately to avoid the experimental bias of other datasets, as [18] constitutes the current standard for unbiased dataset construction. Although there are some natural limitations in our study, our work still constitutes the largest and most comprehensive study of malware evasion to date, comprising 379,680 attack evaluations (Appendix D) in order to isolate improvements in attacker strategy.

7 Related Work

Malware Evasion. In AML, *feature-space* attacks perturb the input vector of the classifier directly. They were initially formalized for security by [8] and then popularized in computer vision by [33] and [14]. In the domain of (Android) malware detection [34] uses saliency maps to perturb features, causing the inverse mapping problem: perturbations do not necessarily correspond to a real program [59]. *Problem-space* attacks avoid this problem by modifying the application itself: [59] introduces the realizability, plausibility, preprocessing-robustness, and semantic-preservation constraints, in addition to APG. Similarly, [11] and [35] harvest and transplant code gadgets under gray-box access. While many works develop their own capability sets, such as [65], REPLICANT presents a novel way to *learn* evasion strategies. Conversely, DRL-based problem-space evasion for malware is instead a relatively nascent field in the Android domain and is primarily concentrated in the neighboring Windows PE domain including the approaches we adapted [44, 60, 63, 69, 79] and other work such as [76], which evades dynamic detectors.

Black-Box Attacks. Boundary [12] and HopSkipJumpAttack [15] popularized decision-based attacks in vision, and [20] extended querying attacks to minimize detected queries in the process, while [26] and [17] improve query efficiency by using transfer-based and Bayesian priors. [24, 64] target sequence-based classifiers and [62] propose a stateful defense against this type of attack. Finally, [75] use DRL to optimize both the offensive and defensive sides during query-

based attacks. Contrary to decision/query-based, transferability attacks optimize against a surrogate and rely on decision-boundary alignment; [22] provide the foundational analysis of why and when adversarial examples transfer, attributing success to gradient and boundary alignment between surrogate and target. REPLICANT instead combines transfer and query based attacks into a single threat model. In doing so it learns a policy that transfers across classifiers and feature spaces while minimizing queries used.

Adversarial Training. Designing malware detectors that are naturally harder to evade dates back to [21] and later [47], which manipulates features and their input weight for robustness. Yet such classifiers can still be evaded, adversarial training was thus introduced to retrain classifiers with malicious samples to reduce evasion rates [49]. More recent work moves adversarial training into the problem space: [81] and [73] introduce a continuous attack-and-retrain pipeline for Android and Windows PE detectors, respectively. [48] study adversarial training for raw-bytes classifiers, investigating the impact of problem-space transformations as well as AEs that are not problem-space compliant. Although robustness and temporal drift are typically studied in isolation, we draw on the temporal-drift and active-learning literature motivating our RQ5. Tesseract [41, 58] and [3] establish the evaluation methodology we adopt, [52, 53] study the interaction between AL and adversarial data poisoning. Our work complements this literature by showing that neither adversarial training nor AL alone is sufficient, and that only their interleaving (RAL) preserves both properties simultaneously.

8 Conclusion

We present REPLICANT, a hierarchical DRL framework that reframes problem-space malware evasion as a *policy* learning problem rather than a per-sample optimization problem. Given a set of problem-space capabilities and a surrogate, REPLICANT learns both *what* capability to apply and *when* to query, yielding a query-efficient black-box attack that transfers across classifier architectures and feature spaces. Across seven classifiers, three feature spaces, and two training periods, *transferring the REPLICANT policy* evades, on average over all settings, 78.8% of samples within twenty queries. Conversely, *sample transfer* succeeds in 43.3% of the cases, while prior Android attacks achieve 65.2%–56.6%. For adversarial training, REPLICANT_{WB} drives residual attack success below 17% against both itself and APG, while staying more robust than AT-APG to unseen capabilities. Furthermore, we show that maintaining robustness while maximizing clean performance across three years of drifting samples requires interleaving both AL and AT. Together, these results establish learned policies as a state-of-the-art foundation for both attacking and adversarially training malware detectors.

References

- [1] Salim Al Wahaibi, Myles Foley, and Sergio Maffei. SQIRL: Grey-Box Detection of SQL Injection Vulnerabilities Using Reinforcement Learning. In *32nd USENIX Security Symposium (USENIX Security 23)*, pages 6097–6114, 2023.
- [2] Kevin Allix, Tegawendé F. Bissyandé, Jacques Klein, and Yves Le Traon. Androzoo: Collecting millions of android apps for the research community. In *Proceedings of the 13th International Conference on Mining Software Repositories, MSR '16*, pages 468–471, New York, NY, USA, 2016. ACM.
- [3] Daniel Arp, Erwin Quiring, Feargus Pendlebury, Alexander Warnecke, Fabio Pierazzi, Christian Wressneger, Lorenzo Cavallaro, and Konrad Rieck. Dos and Don'ts of Machine Learning in Computer Security. In *Proc. of the USENIX Security Symposium*, 2022.
- [4] Daniel Arp, Michael Spreitzenbarth, Malte Hubner, Hugo Gascon, Konrad Rieck, and CERT Siemens. Drebin: Effective and Explainable Detection of Android Malware in your Pocket. In *Ndss*, volume 14, pages 23–26, 2014.
- [5] Kai Arulkumaran, Marc Peter Deisenroth, Miles Brundage, and Anil Anthony Bharath. Deep reinforcement learning: A brief survey. *IEEE Signal Processing Magazine*, 34(6):26–38, 2017.
- [6] Federico Barbero, Feargus Pendlebury, Fabio Pierazzi, and Lorenzo Cavallaro. Transcending Transcend: Revisiting Malware Classification in the Presence of Concept Drift. In *2022 IEEE Symposium on Security and Privacy (SP)*, pages 805–823. IEEE, 2022.
- [7] Elizabeth Bates, Vasilios Mavroudis, and Chris Hicks. Reward shaping for happier autonomous cyber security agents. In *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security*, pages 221–232, 2023.
- [8] Battista Biggio, Igino Corona, Davide Maiorca, Blaine Nelson, Nedim Šrđić, Pavel Laskov, Giorgio Giacinto, and Fabio Roli. Evasion attacks against machine learning at test time. In *Machine Learning and Knowledge Discovery in Databases: European Conference, ECML PKDD 2013, Prague, Czech Republic, September 23-27, 2013, Proceedings, Part III 13*, pages 387–402. Springer, 2013.
- [9] Battista Biggio and Fabio Roli. Wild patterns: Ten years after the rise of adversarial machine learning. In *Proceedings of the 2018 ACM SIGSAC Conference on Computer and Communications Security*, pages 2154–2156, 2018.
- [10] Hamid Bostani, Jacopo Cortellazzi, Daniel Arp, Fabio Pierazzi, Veelasha Moonsamy, and Lorenzo Cavallaro. On the effectiveness of adversarial training on malware classifiers. *arXiv preprint arXiv:2412.18218*, 2024.
- [11] Hamid Bostani and Veelasha Moonsamy. Evadedroid: A practical evasion attack on machine learning for black-box android malware detection. *Computers & Security*, 139:103676, 2024.
- [12] Wieland Brendel, Jonas Rauber, and Matthias Bethge. Decision-based adversarial attacks: Reliable attacks against black-box machine learning models. *arXiv preprint arXiv:1712.04248*, 2017.
- [13] Nicholas Carlini, Anish Athalye, Nicolas Papernot, Wieland Brendel, Jonas Rauber, Dimitris Tsipras, Ian Goodfellow, Aleksander Madry, and Alexey Kurakin. On evaluating adversarial robustness. *arXiv preprint arXiv:1902.06705*, 2019.
- [14] Nicholas Carlini and David Wagner. Towards evaluating the robustness of neural networks. In *2017 IEEE Symposium on Security and Privacy (SP)*, pages 39–57. Ieee, 2017.
- [15] Jianbo Chen, Michael I Jordan, and Martin J Wainwright. Hopskipjumpattack: A query-efficient decision-based attack. In *2020 IEEE Symposium on Security and Privacy (SP)*, pages 1277–1294. IEEE, 2020.
- [16] Yizheng Chen, Zhoujie Ding, and David Wagner. Continuous learning for android malware detection. In *USENIX Security Symposium*, 2023.
- [17] Shuyu Cheng, Yibo Miao, Yinpeng Dong, Xiao Yang, Xiao-Shan Gao, and Jun Zhu. Efficient black-box adversarial attacks via Bayesian optimization guided by a function prior. In Ruslan Salakhutdinov, Zico Kolter, Katherine Heller, Adrian Weller, Nuria Oliver, Jonathan Scarlett, and Felix Berkenkamp, editors, *Proceedings of the 41st International Conference on Machine Learning*, volume 235 of *Proceedings of Machine Learning Research*, pages 8163–8183. PMLR, 21–27 Jul 2024.
- [18] Theo Chow, Mario D’Onghia, Lorenz Linhardt, Zeliang Kan, Daniel Arp, Lorenzo Cavallaro, and Fabio Pierazzi. Beyond the tesseract: Trustworthy dataset curation for sound evaluations of android malware classifiers. *arXiv preprint arXiv:2506.23814*, 2025.
- [19] Jacopo Cortellazzi, Erwin Quiring, Daniel Arp, Feargus Pendlebury, Fabio Pierazzi, and Lorenzo Cavallaro. Intriguing properties of adversarial ml attacks in the problem space [extended version]. *ACM Transactions on Privacy and Security*, 28(4):1–37, 2025.

- [20] Edoardo Debenedetti, Nicholas Carlini, and Florian Tramèr. Evading black-box classifiers without breaking eggs. In *2024 IEEE Conference on Secure and Trustworthy Machine Learning (SaTML)*, pages 408–424. IEEE, 2024.
- [21] Ambra Demontis, Marco Melis, Battista Biggio, Davide Maiorca, Daniel Arp, Konrad Rieck, Iginio Corona, Giorgio Giacinto, and Fabio Roli. Yes, machine learning can be more secure! a case study on android malware detection. *IEEE transactions on dependable and secure computing*, 16(4):711–724, 2017.
- [22] Ambra Demontis, Marco Melis, Maura Pintor, Matthew Jagielski, Battista Biggio, Alina Oprea, Cristina Nita-Rotaru, and Fabio Roli. Why Do Adversarial Attacks Transfer? Explaining Transferability of Evasion and Poisoning Attacks. In *28th USENIX security symposium (USENIX security 19)*, pages 321–338, 2019.
- [23] Janez Demšar. Statistical comparisons of classifiers over multiple data sets. *Journal of Machine learning research*, 7(Jan):1–30, 2006.
- [24] Gabriele Digregorio, Salvatore Maccarrone, Mario D’Onghia, Luigi Gallo, Michele Carminati, Mario Polino, and Stefano Zanero. Tarallo: Evading behavioral malware detectors in the problem space. In *International Conference on Detection of Intrusions and Malware, and Vulnerability Assessment*, pages 128–149. Springer, 2024.
- [25] Jia Ding and Zhiwu Xu. Adversarial attacks on deep learning models of computer vision: A survey. In *Algorithms and Architectures for Parallel Processing: 20th International Conference, ICA3PP 2020, New York City, NY, USA, October 2–4, 2020, Proceedings, Part III 20*, pages 396–408. Springer, 2020.
- [26] Yinpeng Dong, Shuyu Cheng, Tianyu Pang, Hang Su, and Jun Zhu. Query-efficient black-box adversarial attacks guided by a transfer-based prior. *IEEE Transactions on Pattern Analysis and Machine Intelligence*, 44(12):9536–9548, 2021.
- [27] Yinpeng Dong, Fangzhou Liao, Tianyu Pang, Hang Su, Jun Zhu, Xiaolin Hu, and Jianguo Li. Boosting adversarial attacks with momentum. In *Proceedings of the IEEE conference on computer vision and pattern recognition*, pages 9185–9193, 2018.
- [28] Salijona Dyrnishi, Salah Ghamizi, Thibault Simonetto, Yves Le Traon, and Maxime Cordy. On the empirical effectiveness of unrealistic adversarial hardening against realistic adversarial attacks. In *2023 IEEE Symposium on Security and Privacy (SP)*, pages 1384–1400, 2023.
- [29] Marc-Antoine Faillon, Baptiste Bout, Julien Francq, Christopher Neal, Nora Boulahia-Cuppens, Frédéric Cuppens, and Reda Yaich. How to better fit reinforcement learning for pentesting: A new hierarchical approach. In *European Symposium on Research in Computer Security*, pages 313–332. Springer, 2024.
- [30] Myles Foley, Chris Hicks, Kate Highnam, and Vasilios Mavroudis. Autonomous Network Defence Using Reinforcement Learning. In *Proceedings of the 2022 ACM on Asia Conference on Computer and Communications Security, ASIA CCS ’22*, pages 1252–1254. Association for Computing Machinery, 2022.
- [31] Myles Foley and Sergio Maffei. HAXSS: Hierarchical Reinforcement Learning for XSS Payload Generation. In *2022 IEEE International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom)*, pages 147–158. IEEE, 2022.
- [32] Myles Foley, Mia Wang, Zoe M, Chris Hicks, and Vasilios Mavroudis. Inroads into Autonomous Network Defence using Explained Reinforcement Learning. In *Conference on Applied Machine Learning in Information Security (CAMLIS)*, 2022.
- [33] Ian J Goodfellow, Jonathon Shlens, and Christian Szegedy. Explaining and harnessing adversarial examples. *arXiv preprint arXiv:1412.6572*, 2014.
- [34] Kathrin Grosse, Nicolas Papernot, Praveen Manoharan, Michael Backes, and Patrick McDaniel. Adversarial examples for malware detection. In *Computer Security—ESORICS 2017: 22nd European Symposium on Research in Computer Security, Oslo, Norway, September 11–15, 2017, Proceedings, Part II 22*, pages 62–79. Springer, 2017.
- [35] Ping He, Yifan Xia, Xuhong Zhang, and Shouling Ji. Efficient query-based attack against ml-based android malware detection under zero knowledge setting. In *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security*, pages 90–104, 2023.
- [36] Chris Hicks, Elizabeth Bates, Shae McFadden, Isaac Symes Thompson, Myles Foley, Ed Chapman, Nickolas Espinosa Dice, Ankita Samaddar, Joshua Sylvester, Himanshu Neema, et al. Building better environments for autonomous cyber defence. *arXiv preprint arXiv:2604.08805*, 2026.
- [37] Shengyi Huang, Rousslan Fernand Julien Dossa, Chang Ye, Jeff Braga, Dipam Chakraborty, Kinal Mehta, and João G. M. Araújo. Cleanrl: High-quality single-file implementations of deep reinforcement learning algorithms. *Journal of Machine Learning Research*, 23(274):1–18, 2022.

- [38] Shengyi Huang and Santiago Ontañón. A closer look at invalid action masking in policy gradient algorithms. *arXiv preprint arXiv:2006.14171*, 2020.
- [39] Roberto Jordaney, Kumar Sharad, Santanu K Dash, Zhi Wang, Davide Papini, Ilia Nouretdinov, and Lorenzo Cavallaro. Transcend: Detecting Concept Drift in Malware Classification Models. In *26th USENIX Security Symposium (USENIX Security 17)*, pages 625–642, 2017.
- [40] Leslie Pack Kaelbling, Michael L Littman, and Andrew W Moore. Reinforcement learning: A survey. *Journal of artificial intelligence research*, 4:237–285, 1996.
- [41] Zeliang Kan, Shae McFadden, Daniel Arp, Feargus Pendlebury, Roberto Jordaney, Johannes Kinder, Fabio Pierazzi, and Lorenzo Cavallaro. Tesseract: Eliminating experimental bias in malware classification across space and time (extended version). *arXiv preprint arXiv:2402.01359*, 2024.
- [42] Tejas D Kulkarni, Karthik Narasimhan, Ardavan Saeedi, and Josh Tenenbaum. Hierarchical deep reinforcement learning: Integrating temporal abstraction and intrinsic motivation. *Advances in neural information processing systems*, 29, 2016.
- [43] Alexey Kurakin, Ian J Goodfellow, and Samy Bengio. Adversarial examples in the physical world. In *Artificial intelligence safety and security*, pages 99–112. Chapman and Hall/CRC, 2018.
- [44] Raphael Labaca-Castro, Sebastian Franz, and Gabi Dreo Rodosek. Aimerl: Exploring adversarial malware examples with reinforcement learning. In *Machine Learning and Knowledge Discovery in Databases. Applied Data Science Track: European Conference, ECML PKDD 2021, Bilbao, Spain, September 13–17, 2021, Proceedings, Part IV 21*, pages 37–52. Springer, 2021.
- [45] Soyoung Lee, Seongil Wi, and Soeul Son. Link: Black-box detection of cross-site scripting vulnerabilities using reinforcement learning. In *Proceedings of the ACM Web Conference 2022*, pages 743–754, 2022.
- [46] Adrian Shuai Li, Arun Iyengar, Ashish Kundu, and Elisa Bertino. Revisiting concept drift in windows malware detection: Adaptation to real drifted malware with minimal samples. In *32nd Annual Network and Distributed System Security Symposium, NDSS 2025*, 2025.
- [47] Heng Li, Shiyao Zhou, Wei Yuan, Xiapu Luo, Cuiying Gao, and Shuiyan Chen. Robust android malware detection against adversarial example attacks. In *Proceedings of the Web Conference 2021*, pages 3603–3612, 2021.
- [48] Keane Lucas, Samruddhi Pai, Weiran Lin, Lujo Bauer, Michael K Reiter, and Mahmood Sharif. Adversarial training for {Raw-Binary} malware classifiers. In *32nd USENIX Security Symposium (USENIX Security 23)*, pages 1163–1180, 2023.
- [49] Aleksander Madry, Aleksandar Makelov, Ludwig Schmidt, Dimitris Tsipras, and Adrian Vladu. Towards deep learning models resistant to adversarial attacks. *arXiv preprint arXiv:1706.06083*, 2017.
- [50] Shae McFadden, Myles Foley, Elizabeth Bates, Ilias Tsingenopoulos, Sanyam Vyas, Vasilios Mavroudis, Chris Hicks, and Fabio Pierazzi. Sok: The pitfalls of deep reinforcement learning for cybersecurity. *arXiv preprint arXiv:2602.08690*, 2026.
- [51] Shae McFadden, Myles Foley, Mario D’Onghia, Chris Hicks, Vasilios Mavroudis, Nicola Paoletti, and Fabio Pierazzi. Drmd: deep reinforcement learning for malware detection under concept drift. In *Proceedings of the AAAI Conference on Artificial Intelligence*, volume 40, pages 854–862, 2026.
- [52] Shae McFadden, Mark Kan, Lorenzo Cavallaro, and Fabio Pierazzi. The impact of active learning on availability data poisoning for android malware classifiers. In *Proceedings of the Annual Computer Security Applications Conference Workshops (ACSAC Workshops)*. IEEE, 2024.
- [53] Shae McFadden, Zeliang Kan, Lorenzo Cavallaro, and Fabio Pierazzi. Poster: Rpal-recovering malware classifiers from data poisoning using active learning. In *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security*, pages 3561–3563, 2023.
- [54] Shae McFadden, Marcello Maugeri, Chris Hicks, Vasilios Mavroudis, and Fabio Pierazzi. Wendigo: Deep reinforcement learning for denial-of-service query discovery in graphql. In *IEEE Workshop on Deep Learning Security and Privacy (DLSP)*, 2024.
- [55] Seyed-Mohsen Moosavi-Dezfooli, Alhussein Fawzi, and Pascal Frossard. Deepfool: a simple and accurate method to fool deep neural networks. In *Proceedings of the IEEE conference on computer vision and pattern recognition*, pages 2574–2582, 2016.
- [56] Jose G Moreno-Torres, Troy Raeder, Rocío Alaiz-Rodríguez, Nitesh V Chawla, and Francisco Herrera. A Unifying View on Dataset Shift in Classification. *Pattern recognition*, 45(1):521–530, 2012.
- [57] Lucky Onwuzurike, Enrico Mariconti, Panagiotis Andriotis, Emiliano De Cristofaro, Gordon Ross, and Gianluca

- Stringhini. MaMaDroid: Detecting Android Malware by Building Markov Chains of Behavioral Models (Extended Version). *ACM Transactions on Privacy and Security (TOPS)*, 22(2):1–34, 2019.
- [58] Feargus Pendlebury, Fabio Pierazzi, Roberto Jordaney, Johannes Kinder, and Lorenzo Cavallaro. TESSERACT: Eliminating Experimental Bias in Malware Classification across Space and Time. In *28th USENIX Security Symposium (USENIX Security 19)*, pages 729–746, 2019.
- [59] Fabio Pierazzi, Feargus Pendlebury, Jacopo Cortellazzi, and Lorenzo Cavallaro. Intriguing properties of adversarial ml attacks in the problem space. In *2020 IEEE symposium on security and privacy (SP)*, pages 1332–1349. IEEE, 2020.
- [60] Tony Quertier, Benjamin Marais, Stéphane Morucci, and Bertrand Fournel. Merlin–malware evasion with reinforcement learning. *arXiv preprint arXiv:2203.12980*, 2022.
- [61] Erwin Quiring, Alwin Maier, and Konrad Rieck. Misleading authorship attribution of source code using adversarial learning. In *28th USENIX Security Symposium (USENIX Security 19)*, pages 479–496, 2019.
- [62] Aqib Rashid and Jose Such. Malprotect: Stateful defense against adversarial query attacks in ml-based malware detection. *IEEE Transactions on Information Forensics and Security*, 18:4361–4376, 2023.
- [63] Maria Rigaki and Sebastian Garcia. The power of meme: Adversarial malware creation with model-based reinforcement learning. In *European Symposium on Research in Computer Security*, pages 44–64. Springer, 2023.
- [64] Ishai Rosenberg, Asaf Shabtai, Yuval Elovici, and Lior Rokach. Query-efficient black-box attack against sequence-based malware classifiers. In *Proceedings of the 36th annual computer security applications conference*, pages 611–626, 2020.
- [65] Christian Scano, Diego Soi, Angelo Sotgiu, Luca Demetrio, Davide Maiorca, Giorgio Giacinto, Fabio Roli, and Battista Biggio. Droidbreaker: Practical and functional problem-space attacks on machine-learning android malware detectors. *arXiv preprint arXiv:2606.26707*, 2026.
- [66] John Schulman, Filip Wolski, Prafulla Dhariwal, Alec Radford, and Oleg Klimov. Proximal policy optimization algorithms. *arXiv preprint arXiv:1707.06347*, 2017.
- [67] Burr Settles. Active learning literature survey. 2009.
- [68] Ezzeldin Shereen, Dan Ristea, Shae McFadden, Burak Hasircioglu, Vasilios Mavroudis, and Chris Hicks. One pic is all it takes: Poisoning visual document retrieval augmented generation with a single image. *arXiv preprint arXiv:2504.02132*, 2025.
- [69] Wei Song, Xuezixiang Li, Sadia Afroz, Deepali Garg, Dmitry Kuznetsov, and Heng Yin. Mab-malware: A reinforcement learning framework for blackbox generation of adversarial malware. In *Proceedings of the 2022 ACM on Asia conference on computer and communications security*, pages 990–1003, 2022.
- [70] Richard S Sutton and Andrew G Barto. *Reinforcement learning: An introduction*. MIT press, 2018.
- [71] Franco Terranova, Abdelkader Lahmadi, and Isabelle Chrisment. Leveraging deep reinforcement learning for cyber-attack paths prediction: Formulation, generalization, and evaluation. In *Proceedings of the 27th International Symposium on Research in Attacks, Intrusions and Defenses*, pages 1–16, 2024.
- [72] Christy Tila. Market share of mobile operating systems worldwide from 1st quarter 2009 to 4th quarter 2025, by quarter. <https://www.statista.com/statistics/272698/global-market-share-held-by-mobile-operating-systems-since-2009/>, 2026.
- [73] Ilias Tsingenopoulos, Jacopo Cortellazzi, Branislav Bošanský, Simone Aonzo, Davy Preuveneers, Wouter Joosen, Fabio Pierazzi, and Lorenzo Cavallaro. How to train your antivirus: RL-based hardening through the problem space. In *Proceedings of the 27th International Symposium on Research in Attacks, Intrusions and Defenses*, pages 130–146, 2024.
- [74] Ilias Tsingenopoulos, Davy Preuveneers, Lieven Desmet, and Wouter Joosen. Captcha me if you can: Imitation games with reinforcement learning. In *2022 IEEE 7th European Symposium on Security and Privacy (EuroS&P)*, pages 719–735. IEEE, 2022.
- [75] Ilias Tsingenopoulos, Vera Rimmer, Davy Preuveneers, Fabio Pierazzi, Lorenzo Cavallaro, and Wouter Joosen. The adaptive arms race: Redefining robustness in ai security. In *2025 28th International Symposium on Research in Attacks, Intrusions and Defenses (RAID)*, pages 611–628. IEEE, 2025.
- [76] Ilias Tsingenopoulos, Ali Mohammad Shafiei, Lieven Desmet, Davy Preuveneers, and Wouter Joosen. Adaptive malware control: Decision-based attacks in the problem space of dynamic analysis. In *Proceedings of the 1st Workshop on Robust Malware Analysis*, pages 3–14, 2022.

- [77] Yueming Wu, Wenqi Suo, Siyue Feng, Deqing Zou, Wei Yang, Yang Liu, and Hai Jin. Malscan: Android malware detection based on social-network centrality analysis. *IEEE Transactions on Dependable and Secure Computing*, 2025.
- [78] Limin Yang, Zhi Chen, Jacopo Cortellazzi, Feargus Pendlebury, Kevin Tu, Fabio Pierazzi, Lorenzo Cavallaro, and Gang Wang. Jigsaw Puzzle: Selective Backdoor Attack to Subvert Malware Classifiers. *arXiv preprint arXiv:2202.05470*, 2022.
- [79] Dazhi Zhan, Wei Bai, Xin Liu, Yue Hu, Lei Zhang, Shize Guo, and Zhisong Pan. Psp-mal: Evading malware detection via prioritized experience-based reinforcement learning with shapley prior. In *Proceedings of the 39th Annual Computer Security Applications Conference*, pages 580–593, 2023.
- [80] Xiaohan Zhang, Yuan Zhang, Ming Zhong, Daizong Ding, Yinzhi Cao, Yukun Zhang, Mi Zhang, and Min Yang. Enhancing state-of-the-art classifiers with api semantics to detect evolved android malware. In *Proceedings of the 2020 ACM SIGSAC conference on computer and communications security*, pages 757–770, 2020.
- [81] Yinyuan Zhang, Cuiying Gao, Yueming Wu, Shihan Dou, Cong Wu, Ying Zhang, Wei Yuan, and Yang Liu. Fighting fire with fire: Continuous attack for adversarial android malware detection. In *34th USENIX Security Symposium (USENIX Security 25)*, pages 4897–4916, 2025.
- [82] Xinran Zheng, Shuo Yang, Edith C-H Ngai, Suman Jana, and Lorenzo Cavallaro. Tif: Learning temporal invariance in android malware detectors. *IEEE Transactions on Software Engineering*, 2026.

A Common Acronyms

- DRL** Deep Reinforcement Learning
- MDP** Markov Decision Process
- ML** Machine Learning
- AML** Adversarial Machine Learning
- AE** Adversarial Sample
- AT** Adversarial Training
- AL** Active Learning
- RAL** Robust AL
- PTE** Policy Transfer Evasion
- STE** Sample Transfer Evasion
- ASR** Attack Success Rate

B Proximal Policy Optimization

This appendix expands the three components of the PPO objective stated in Equation 2. PPO [66] is an actor-critic, on-policy algorithm that operates as follows: at each iteration, T environment steps are collected under the current policy $\pi_{\theta_{\text{old}}}$ into a rollout buffer $\mathcal{D} = \{(s_t, a_t, r_t, d_t)\}_{t=0}^{T-1}$ (with $d_t \in \{0, 1\}$ denoting if the episode has terminated), and θ is then updated for K epochs of minibatch stochastic gradient descent on $\mathcal{L}^{\text{PPO}}(\theta)$ before a fresh rollout is collected. PPO constrains updates with probability-ratio clipping and has become the de facto standard in the literature.

B.1 Clipped Surrogate Objective

To enable multiple epochs over a single rollout, PPO uses the surrogate

$$\mathbb{E}_t[\rho_t(\theta) \hat{A}_t], \quad \rho_t(\theta) = \frac{\pi_{\theta}(a_t | s_t)}{\pi_{\theta_{\text{old}}}(a_t | s_t)}, \quad (8)$$

where $\pi_{\theta_{\text{old}}}$ is used during rollout and $\rho_t(\theta)$ is the per-step probability ratio between the policies. Maximizing the surrogate without constraining π_{θ} causes too much drift with respect to $\pi_{\theta_{\text{old}}}$ and degrades performance. Therefore, PPO controls this drift via a ratio-clipping mechanism:

$$\mathcal{L}^{\text{P}}(\theta) = \mathbb{E}_t \left[\min \left(\rho_t(\theta) \hat{A}_t, \text{clip}(\rho_t(\theta), 1 - \epsilon, 1 + \epsilon) \hat{A}_t \right) \right], \quad (9)$$

where $\epsilon \in (0, 1)$ is the clip range. The clip bounds ρ_t to $[1 - \epsilon, 1 + \epsilon]$, and the min operator removes the incentive to move the ratio further. When $\hat{A}_t > 0$, the contribution is capped at $(1 + \epsilon)\hat{A}_t$, so raising ρ_t beyond $1 + \epsilon$ yields no further gain; when $\hat{A}_t < 0$, it is floored at $(1 - \epsilon)\hat{A}_t$, so lowering ρ_t below $1 - \epsilon$ yields no further gain. However, if an update has already pushed ρ_t in the wrong direction (i.e., raising the probability of an action with $\hat{A}_t < 0$), then the unclipped term is selected, thereby retaining the gradient needed to correct the policy. The effect of this process is a pessimistic lower bound on policy improvement that discourages destructively large updates.

B.2 Generalized Advantage Estimation

The advantage $\hat{A}_t$ in Equation 9 measures how much better action a_t was than the expected behavior of the policy at s_t . PPO estimates advantage using Generalized Advantage Estimation (GAE), which uses a smoothing parameter $\lambda \in [0, 1]$. Let δ_t denote the one-step temporal-difference (TD) residual computed with respect to the predicted value at rollout time:

$$\delta_t = r_t + \gamma V_{\theta_{\text{old}}}(s_{t+1})(1 - d_{t+1}) - V_{\theta_{\text{old}}}(s_t). \quad (10)$$

The GAE advantage is then the exponentially weighted sum of k -step TD residuals,

$$\hat{A}_t = \sum_{l=0}^{T-t-1} (\gamma\lambda)^l \delta_{t+l}, \quad (11)$$

or equivalently

$$\hat{A}_t = \delta_t + \gamma\lambda(1-d_{t+1})\hat{A}_{t+1}, \quad \hat{A}_T = 0, \quad (12)$$

where $(1-d_{t+1})$ truncates the sum at episode terminations. If $\lambda = 0$, then $\hat{A}_t = \delta_t$ and, therefore, recovers only the one-step TD estimate (low variance, high bias); if $\lambda = 1$, then $\hat{A}_t$ approaches the full Monte-Carlo return (low bias, high variance). Intermediate values (typically $\lambda \in [0.9, 0.99]$) give a preferable bias-variance trade-off. Advantages are computed in a single backward recursion over the rollout, then normalized to zero mean and unit variance within each minibatch before being used in Equation 9.

B.3 Clipped Value Loss

Many implementations of PPO also clip the value loss similar to the clipping performed on the policy objective, bounding how much $V_\theta(s_t)$ can change from $V_{\theta_{\text{old}}}(s_t)$ in a single update:

$$\mathcal{L}^V(\theta) = \frac{1}{2} \mathbb{E}_t \left[\max \left((V_\theta(s_t) - \hat{R}_t)^2, (\tilde{V}_\theta(s_t) - \hat{R}_t)^2 \right) \right], \quad (13)$$

with the clipped value prediction

$$\tilde{V}_\theta(s_t) = V_{\theta_{\text{old}}}(s_t) + \text{clip}(V_\theta(s_t) - V_{\theta_{\text{old}}}(s_t), -\epsilon, \epsilon), \quad (14)$$

so that the clipped prediction $\tilde{V}_\theta(s_t)$ lies within an ϵ -ball of its rollout-time estimate. The max operator selects the prediction that yields the larger squared error. Therefore, when $V_\theta(s_t)$ moves outside the ϵ -ball in a direction that would *reduce* the loss, the clipped term is used; otherwise, the unclipped error is used. This makes $\mathcal{L}^V$ a pessimistic bound on $V_\theta(s_t)$, similar to the role of the min operator in $\mathcal{L}^P$, and improves stability when reward magnitudes are large or the value function has not yet converged.

B.4 Entropy Bonus

Maximizing the surrogate alone tends to collapse the policy onto a near-deterministic behavior. Therefore, to preserve exploration, PPO regularizes the policy with the Shannon entropy of its action distribution,

$$\mathcal{L}^E(\theta) = \mathbb{E}_t [H(\pi_\theta(\cdot | s_t))], \quad (15)$$

$$H(\pi_\theta(\cdot | s_t)) = - \sum_{a \in \mathcal{A}} \pi_\theta(a | s_t) \log \pi_\theta(a | s_t), \quad (16)$$

The coefficient c_e determines the amount of exploration with large c_e values keeping the action distribution flat, while small c_e values allow high determinism as confidence increases.

Algorithm 1 Proximal Policy Optimization (clipped).

Require: initial parameters θ , clip range ϵ , discount γ , GAE parameter λ , coefficients c_v, c_e , epochs K , rollout length T , updates U

- 1: **for** iteration = 1, ..., U **do**
- 2: $\theta_{\text{old}} \leftarrow \theta$
- 3: Roll out $\pi_{\theta_{\text{old}}}$ for T steps;
- 4: store $(s_t, a_t, r_t, d_t, \log \pi_{\theta_{\text{old}}}(a_t | s_t), V_{\theta_{\text{old}}}(s_t))$
- 5: Compute $\{\delta_t\}_{t=0}^{T-1}$ and $\{\hat{A}_t\}_{t=0}^{T-1}$ by Eq. 12
- 6: Compute value targets $\hat{R}_t \leftarrow \hat{A}_t + V_{\theta_{\text{old}}}(s_t)$
- 7: **for** epoch = 1, ..., K **do**
- 8: **for** each minibatch $\mathcal{B} \subset \{0, \dots, T-1\}$ **do**
- 9: Normalize $\{\hat{A}_t\}_{t \in \mathcal{B}}$
- 10: Evaluate $\mathcal{L}^P, \mathcal{L}^V, \mathcal{L}^E$ over $\mathcal{B}$ via Eqs. 9, 13, 15
- 11: $\theta \leftarrow \theta - \eta \nabla_\theta \mathcal{L}^{\text{PPO}}(\theta)$ // gradient-norm clip
- 12: **end for**
- 13: **end for**
- 14: **end for**

B.5 Combined Objective

As presented in Equation 2, the three terms of $\mathcal{L}^P, \mathcal{L}^V, \mathcal{L}^E$ are combined into a single scalar loss to be minimized by stochastic gradient descent. Specifically, $\mathcal{L}^P$ and $\mathcal{L}^E$ are the objectives to maximize, while $\mathcal{L}^V$ is a squared-error loss to be minimized. The pseudo code of PPO is presented in Algorithm 1 and the hyperparameters used in this work are presented in Appendix C. In practice the learning rate η is linearly annealed over the course of training and the global gradient norm is clipped to a fixed value.

C Hyperparameters

Problem-Space Constraints. We manage problem-space conflicts following the implementation of [19], which we requested from the authors. Therefore, prior to selection, action masking removes: (i) gadgets whose Java classes conflict with already-transplanted gadgets, and (ii) gadgets that would exceed the per-gadget budgets of 3 permissions and 60 classes (as set in the provided implementation).

C.1 REPLICANT

We train REPLICANT with PPO [66] using the default hyperparameters of CleanRL [37]: learning rate $\alpha = 2.5 \times 10^{-4}$ (annealed), $\gamma=0.99$, GAE $\lambda=0.95$, clip $\epsilon=0.2$, entropy coefficient 0.01, value coefficient 0.5 with clipped value loss, max gradient norm 0.5, and normalized advantages. Each REPLICANT agent is trained for 50 updates, with each update using 500 episodes per batch, 250 steps per minibatch, and 3 epochs over all minibatches. Each episode runs for a maximum horizon of $H = 100$ steps, with a forced SUBMIT every $p = 10$ steps. The architecture of REPLICANT is based on

DRMD [51], given its state-of-the-art detection performance in the domain, but extended to learn the hierarchical evasion policy. Specifically, REPLICANT uses a shared two-layer MLP encoder (512 neurons, LeakyReLU, dropout) feeding three heads, each adding one further 512-neuron layer: a *query* head over $\{\text{SUBMIT}, \text{MODIFY}\}$, a *modify* head over the capability set C , and a *critic* head estimating $V(s_t)$. During training, the agent samples from the action distribution to allow for effective action space exploration, whereas during evaluation it selects the highest-probability action to exploit the knowledge learned in training.

C.2 Classifiers

RandomForest [57]. Scikit-learn implementation with 101 estimators, max depth 64, and parallel fitting ($n_jobs=-2$).

LinearSVC [4]. Scikit-learn LinearSVC with max iterations 50,000 and default regularization.

SecSVM [21]. trained via full-batch GPU sub-gradient descent with $C=1.0$, weight bounds $[-0.5, 0.5]$, learning rate $\eta=0.5$, convergence threshold $\epsilon=10^{-4}$, and max 10,000 iterations.

DeepDrebin [34]. Two-hidden-layer MLP (200×200 , ReLU) trained with SGD at $\text{lr}=0.05$ for 10 epochs (batch size 512), repeated over 5 training loops with validation-based checkpoint selection.

DRMD [51]. PPO-based DRL classifier with a 3×512 -unit MLP (LeakyReLU, dropout 0.5), trained for 5 epochs with learning rate 2.5×10^{-4} (annealed), $\gamma=0.99$, GAE $\lambda=0.95$, clip $\epsilon=0.2$, entropy coefficient 0.01, minibatch size 250, and 1 PPO update epoch per training epoch.

HCC [16]. Contrastive learning classifier with a 4-layer encoder ($512 \rightarrow 384 \rightarrow 256 \rightarrow 128$, ReLU) and a 3-layer MLP head ($128 \rightarrow 100 \rightarrow 100 \rightarrow 2$, ReLU, dropout 0.2). Trained for 40 epochs (batch size 1,024) with contrastive loss weight $\lambda=100$ and margin 10.

RAMDA [47]. Two-phase architecture: a VAE ($n_{\text{features}} \rightarrow 600 \rightarrow 600 \rightarrow 80$ latent, dropout 0.1) followed by a 4-layer detection MLP ($80 \rightarrow 40 \rightarrow 40 \rightarrow 40 \rightarrow 2$, dropout 0.1). Both trained for 50 epochs with a threshold $v=30$.

C.3 Baselines

For fair comparison and to maintain realizability, all baselines use the same problem-space constraints as REPLICANT.

APG [19, 59]. Greedily selects capabilities ordered by their contribution to the decision function of the classifier. For linear classifiers (LinearSVC, SecSVM), contribution is computed via weight-based projection; for neural classifiers, a score-based approximation is used.

ADZ [35]. Operates over a perturbation space of 662 actions (143 manifest features and 519 code features) organized in a hierarchical selection tree. At each step, a perturbation is sampled from the tree and applied, then the modified sample

is submitted to the classifier and the tree is updated based on the change in the confidence of the classifier. As shown in Appendix 10, the ADZ method does not scale to larger capability sets, therefore, ADZ is the only exception to the shared capability set across attackers. We instead reconstruct a 662-action space from our capability set following the subset of manifest and code perturbations specified in the original work.

EvadeDroid [11]. At each step, samples and applies an untried capabilities at random, and queries the target classifier. If the sampled capability does not decrease the classifier confidence then it is removed from the malware. Every iteration queries the target classifier once. Results are averaged over 5 independent trials per seed.

Rnd [50]. At each step, randomly selects a query action (MODIFY/SUBMIT) and a capability, uniformly at random, from the valid (masked) action set. Results are averaged over 5 independent trials per seed.

C.4 RL-Based Attacks

MEME [63]. A PPO attack for model-extraction and evasion; we collapse its extraction stage and instead train the agent directly against the shared surrogate using the Optuna-tuned hyperparameters from the paper ($\text{lr}=1.38 \times 10^{-3}$, $\gamma=0.854$, $\text{max-grad-norm}=0.428$, 10 epochs) with SB3 (Stable Baselines 3) defaults otherwise ($n_{\text{steps}}=128$, minibatch 64, GAE $\lambda=0.95$, clip 0.2, entropy 0, value 0.5), over the paper’s fixed training budget of 6,144 environment steps. The reward function of MEME is +10 on evasion and otherwise the step-wise reduction in the malicious score of the surrogate.

MAB [69]. Thompson-sampling multi-armed bandit in which each capability is an arm with a Beta(α, β) posterior initialized at $\alpha=\beta=1$. At each step it draws a value from every arm and applies the highest-drawn valid capability; a leave-one-out minimization pass then prunes redundant capabilities and credits the posteriors from the outcome ($\alpha+1$ for capabilities whose removal breaks evasion, $\beta+1$ for redundant ones), reinforcing the arms useful for evasion. Results are averaged over 5 trials per seed.

MERLIN [60]. Deep Q Network (DQN) with a two-layer 128-unit MLP (ReLU), Adam $\text{lr}=2.5 \times 10^{-4}$, $\gamma=0.99$, uniform replay of 10k, batch 32, hard target-update every 500 steps, 1,000 training episodes, and ϵ annealed to 0.05 over the first half of training, rewarded +10 on evasion and otherwise by the step-wise reduction in the confidence score of the surrogate.

AIMED-RL [44]. Distributional Double-DQN with NoisyNet exploration ($\sigma_0=0.5$) and proportional prioritized replay ($\alpha=0.6$, $\beta:0.4 \rightarrow 1$); $\gamma=0.95$, Adam($\text{lr}=10^{-3}$, $\epsilon=10^{-2}$), batch 32, target-update every 100 steps, and a 1,000 episodes training budget. Its reward function is comprised of an evasion bonus (+10), a distance reward in terms of capabilities applied, a similarity reward in terms

of the actual changes to the file, and a penalty for repeated capabilities.

PSP-Mal [79]. Dueling Double-DQN with soft target updates ($\tau=0.005$), Adam lr= 3×10^{-4} , $\gamma=0.99$, batch 256, replay of 500k, ϵ annealed 1.0 $\rightarrow$ 0.1, and a training budget of 1,000 episodes. Its reward function is +10 on evasion and otherwise the reduction of the confidence score from the original sample. Its prioritized replay adds a Shapley-style prior, which we compute on the surrogate to maintain parity between attackers.

D Scale of Experiments

Across all experiments for the main results of the paper we conducted 379,680 attack evaluations, we further breakdown this total by section. For Sections 5.1-5.2, the ten attacks are evaluated across 1,764 surrogate/target combinations (7×7 classifiers, 3×3 feature spaces, and 2×2 training periods), two dataset variants, and ten seeds, totaling 352,800 attack evaluations. For Sections 5.3-5.4, 10,080 attack evaluations and 560 hardened classifiers (8,400 AT rounds) were produced across the seven classifiers, ten seeds, two training periods, two pipelines, two AT capability sets, and six attacker capability sets. Lastly, Section 5.5 tracks monthly performance of five detection pipelines across seven classifiers, two training periods, and ten seeds, leading to 16,800 attack evaluations across the 2022–2024 period. To our knowledge this is the largest evaluation of malware evasion to date, delineating the performance differences of attack *strategies* rather than that of capability set or threat model.

E Extended Evaluations

The following tables and figures support the evaluations described in Section 5.1: the effect of the VirusTotal labeling threshold on FNR (Table 6); the attack results on Hypercube_{VTT4} (Table 7); the attack results for the different time-period splits of the Hypercube (VTT2) dataset (Table 8); and, the per-classifier and per-space-pair breakdowns of the transferability curves that Figure 2 aggregates (Figures 6-8).

Table 6: **FNRs between VTTs**, target classifier false-negative rate (FNR, %) on malware by period. Reported using 2021*b* targets for full dataset coverage. 2021*a* is the surrogate held-out set; 2022–2024 are the temporally split test years. FNRs are averaged over the seven target classifiers, three feature spaces, and ten seeds; the final column averages across the three periods. As Hypercube_{VTT4} contains no 2024 malware, its 2024 entry is omitted and its mean is taken over 2021–2023.

Dataset	2021 <i>a</i>	2022	2023	2024	Mean
VTT2	35.6 $\pm$ 0.4	63.8 $\pm$ 0.6	86.6 $\pm$ 0.5	95.0 $\pm$ 0.4	70.2 $\pm$ 0.3
VTT4	15.6 $\pm$ 0.2	46.9 $\pm$ 0.6	66.2 $\pm$ 0.5	—	42.9 $\pm$ 0.3

Table 7: **VTT4 Results**, Attacker comparison on Hypercube_{VTT4} for both the *matched* and *all* settings, reporting mean ASR and AvgQ for both, with per target breakdown for matched.

Matched	REPLICANT	APG	ADZ	EvD	Rnd
SVM	100.0 ^{***} _{$\pm$0.0}	100.0 ^{***} _{$\pm$0.0}	88.2 $\pm$ 0.9	96.6 $\pm$ 0.2	91.0 $\pm$ 1.1
SecSVM	100.0 ^{***} _{$\pm$0.0}	100.0 ^{***} _{$\pm$0.0}	71.4 $\pm$ 3.4	89.2 $\pm$ 0.8	74.5 $\pm$ 2.6
RF	93.8 ^{***} _{$\pm$1.6}	91.0 $\pm$ 1.6	90.0 $\pm$ 1.6	91.1 $\pm$ 1.6	91.1 $\pm$ 1.6
DeepDrebin	100.0 ^{***} _{$\pm$0.0}	100.0 ^{***} _{$\pm$0.0}	86.9 $\pm$ 1.9	91.9 $\pm$ 1.6	88.3 $\pm$ 1.4
RAMDA	99.8 ^{***} _{$\pm$0.3}	83.7 $\pm$ 3.6	84.3 $\pm$ 2.8	77.9 $\pm$ 2.9	86.4 $\pm$ 1.4
HCC	99.9 ^{***} _{$\pm$0.1}	99.3 $\pm$ 0.7	90.4 $\pm$ 1.4	92.5 $\pm$ 1.6	92.0 $\pm$ 1.4
DRMD	100.0 ^{***} _{$\pm$0.0}	59.7 $\pm$ 3.0	60.9 $\pm$ 2.6	74.9 $\pm$ 1.7	57.0 $\pm$ 1.4
ASR	99.0 ^{***} _{$\pm$0.2}	90.5 $\pm$ 0.9	81.8 $\pm$ 1.6	87.7 $\pm$ 1.0	82.9 $\pm$ 0.6
AvgQ	2.6 ^{***} _{$\pm$0.1}	3.8 ^{***} _{$\pm$0.2}	7.5 $\pm$ 0.3	6.5 $\pm$ 0.2	6.6 $\pm$ 0.2
All Settings	REPLICANT	APG	ADZ	EvD	Rnd
ASR	94.1 ^{***} _{$\pm$0.9}	83.8 $\pm$ 1.1	82.0 $\pm$ 1.5	78.2 $\pm$ 1.2	81.8 $\pm$ 1.0
AvgQ	5.1 ^{***} _{$\pm$0.3}	6.0 $\pm$ 0.3	7.4 $\pm$ 0.3	8.1 $\pm$ 0.3	6.6 $\pm$ 0.3

Table 8: **Test Splits Performance**, ASR for the attacks over all settings by test period *relative* to the training year of the target, averaged over the 2021*b*- and 2022*b*-trained targets. +0 is the surrogate split of the training year (2021*a* for a 2021*b* target, 2022*a* for a 2022*b* target); +1 is the main test setting used in Sections 5.1-5.2; +2/+3 test further into the future. +3 has only the 2021*b*-trained targets as dataset does not contain 2025 samples.

Test period	REPLICANT	APG	ADZ	EvD	Rnd
+0	70.0 ^{***} _{$\pm$1.3}	53.4 $\pm$ 0.7	49.7 $\pm$ 1.5	43.8 $\pm$ 0.8	46.2 $\pm$ 1.0
+1	78.7 ^{***} _{$\pm$1.2}	65.0 $\pm$ 0.9	61.0 $\pm$ 1.2	56.4 $\pm$ 0.9	58.9 $\pm$ 0.9
+2	89.4 ^{***} _{$\pm$1.3}	82.8 $\pm$ 0.9	77.5 $\pm$ 1.4	75.7 $\pm$ 1.4	77.1 $\pm$ 1.3
+3	95.4 ^{***} _{$\pm$1.2}	91.9 $\pm$ 1.2	86.8 $\pm$ 1.5	86.8 $\pm$ 1.6	87.6 $\pm$ 1.2
All	73.1 ^{***} _{$\pm$1.2}	57.2 $\pm$ 0.7	53.5 $\pm$ 1.3	48.0 $\pm$ 0.7	50.5 $\pm$ 0.9

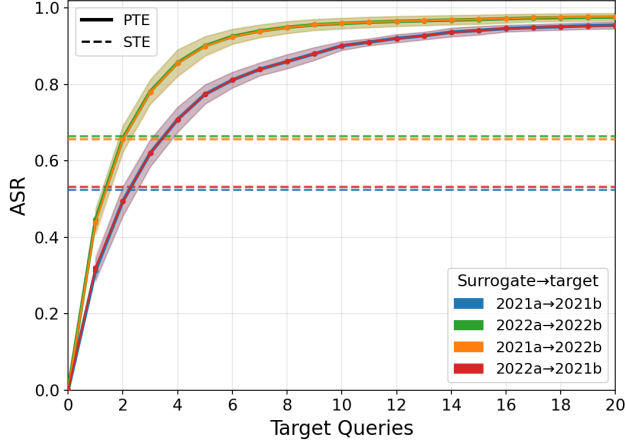


Figure 5: **Temporal gap**, per training-period pair: Solid curves plot the ASR of PTE over target queries and the dashed horizontal lines demonstrate the ASR of STE. Aggregated as the *temporal gap* row of Table 2 and the purple curve of Figure 2. The cross-period curves follow the matched-period curves with the same target training period, showing both the effect of temporal luck and that the temporal gap is negligible.

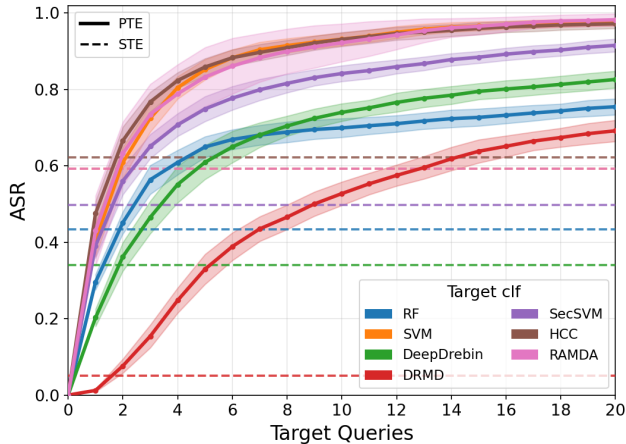


Figure 6: **Architecture gap**, per target classifier: Solid curves plot the ASR of PTE over target queries and the dashed horizontal lines demonstrate the ASR of STE. Aggregated as the *architecture gap* row of Table 2 and the green curve of Figure 2.

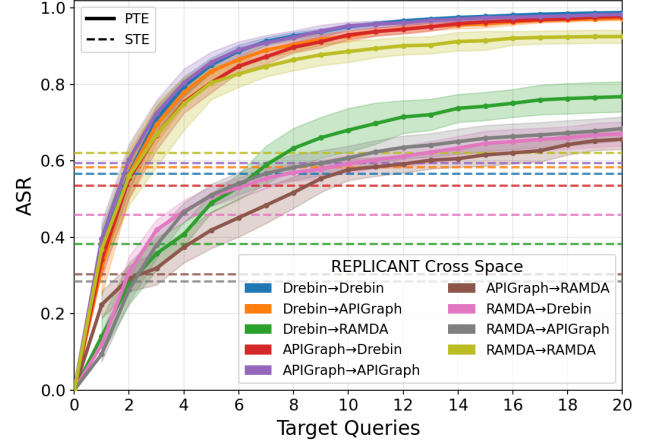


Figure 7: **Representation gap**, per feature-space pair: Solid curves plot the ASR of PTE over target queries and the dashed horizontal lines demonstrate the ASR of STE. Aggregated as the *representation gap* row of Table 2 and the orange curve of Figure 2.

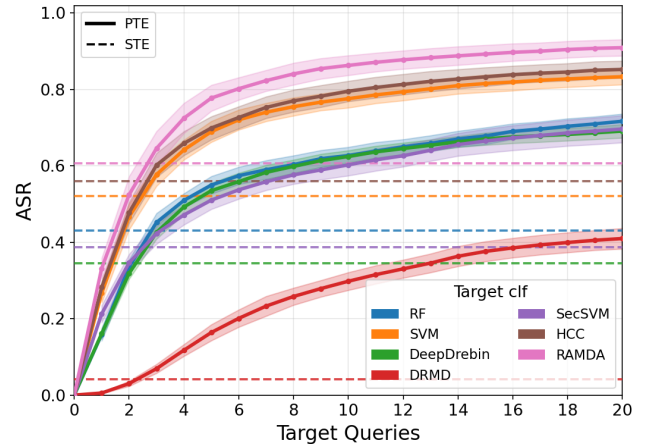


Figure 8: **Combined gap**, per target classifier: Solid curves plot the ASR of PTE over target queries and the dashed horizontal lines demonstrate the ASR of STE. Aggregated as the *combined gap* row of Table 2 and the red curve of Figure 2.

F RL Design Ablation

To isolate the gains provided by the architecture of our agent and its reward function over prior RL-based work, we compare against five alternative state-of-the-art RL agent designs for malware evasion: MEME [63], MAB [69], MRLN [60], AIM [44], PSP [79]. As each of these five RL-based attacks were originally proposed for Windows PE malware evasion, we adapted them to Android by modifying them to use our

environment, threat model, and capability set. Results for this comparison can be seen in Table 9 and Figure 9.

Table 9: **RL Design Comparison.** Comparison between REPLICANT and prior RL-based attacks designs for Windows PE malware adapted to our environment, threat model, and shared capability set. Results are evaluated and reported following the methodology of Table 1. REPLICANT remains the strongest attacker with statistically significant gains across all settings.

Matched	REPLICANT	MEME	MAB	PSP	MRLN	AIM
SVM	99.1^{***} 98.6 $\pm$ 1.5	98.6 $\pm$ 1.5	98.0 $\pm$ 2.3	77.3 $\pm$ 5.2	71.0 $\pm$ 6.6	72.0 $\pm$ 9.4
SecSVM	98.2^{***} 95.1 $\pm$ 1.0	95.1 $\pm$ 1.2	94.1 $\pm$ 1.0	59.6 $\pm$ 4.7	58.7 $\pm$ 4.3	45.7 $\pm$ 8.1
RF	93.3^{***} 91.7 $\pm$ 1.7	74.9 $\pm$ 2.6	76.2 $\pm$ 2.9	67.0 $\pm$ 3.0	62.1 $\pm$ 2.8	65.7 $\pm$ 3.8
DeepDrebin	96.5^{***} 92.1 $\pm$ 2.1	84.7 $\pm$ 3.5	72.4 $\pm$ 2.9	59.4 $\pm$ 2.5	51.1 $\pm$ 4.2	49.3 $\pm$ 5.6
RAMDA	99.9^{***} 90.1 $\pm$ 0.1	95.8 $\pm$ 4.9	95.5 $\pm$ 5.6	83.4 $\pm$ 3.3	76.6 $\pm$ 9.3	80.0 $\pm$ 5.6
HCC	98.7^{***} 90.9 $\pm$ 0.9	96.8 $\pm$ 1.5	96.3 $\pm$ 1.6	80.0 $\pm$ 3.3	78.9 $\pm$ 4.0	78.8 $\pm$ 4.3
DRMD	90.2^{***} 82.7 $\pm$ 2.7	83.1 $\pm$ 4.4	66.7 $\pm$ 2.5	20.6 $\pm$ 2.4	31.7 $\pm$ 7.5	17.1 $\pm$ 4.9
ASR	96.6^{***} 90.7 $\pm$ 0.7	89.8 $\pm$ 1.1	85.6 $\pm$ 1.6	63.9 $\pm$ 1.8	61.5 $\pm$ 2.0	58.4 $\pm$ 2.2
AvgQ	3.6^{***} 3.0 $\pm$ 0.3	5.1 $\pm$ 0.3	6.0 $\pm$ 0.3	10.2 $\pm$ 0.3	11.5 $\pm$ 0.3	13.8 $\pm$ 0.3
All Settings	REPLICANT	MEME	MAB	PSP	MRLN	AIM
ASR	78.8^{***} 71.2 $\pm$ 1.2	73.2 $\pm$ 0.9	71.2 $\pm$ 0.9	59.7 $\pm$ 1.2	59.5 $\pm$ 1.4	56.6 $\pm$ 1.5
AvgQ	7.4^{***} 7.0 $\pm$ 0.2	8.5 $\pm$ 0.2	9.0 $\pm$ 0.2	11.0 $\pm$ 0.2	11.3 $\pm$ 0.2	12.6 $\pm$ 0.3

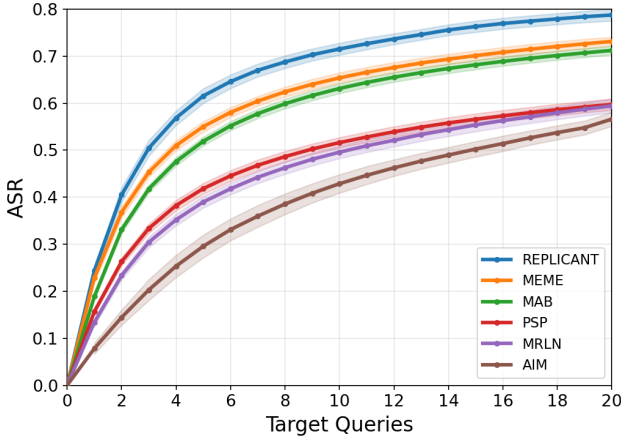


Figure 9: **RL Design Curves.** Attack efficiency across all 1,764 surrogate/target combinations and ten seeds. REPLICANT outperforms every other RL agent design with the highest evasion rate per query.

G Motivating Ablations

This appendix motivates three design decisions: the scaling of training budget in AT-REPLICANT (Table 12); the reduced ADZ capability set (Table 10), and the effect of surrogate/test overlap in the 2022a $\rightarrow$ 2021b setting (Table 11).

Table 10: **Ablation: ADZ Capability Set,** the mean ASR performance of ADZ decreases when it is given the full capability set, demonstrating that it does not scale and motivating our use of the reduced 662-set following the constraints of the original work [35]. Although reduced when using the smaller 662-set, REPLICANT still remains significantly stronger than ADZ. Experiments conducted using: the 2021a $\rightarrow$ 2021b training period, Drebin feature space, five seeds, and seven classifiers; results reported as mean ASR for matched settings.

Strategy	ADZ 662-set	Full Capability Set
ADZ	51.8 $\pm$ 1.5	34.7 $\pm$ 3.9
REPLICANT	76.6 $\pm$ 4.5	95.5 $\pm$ 0.9

Table 11: **Ablation: Surrogate Overlap,** evaluation of the impact that the inclusion of 2022a data has on the mean ASR for the 2022a $\rightarrow$ 2021b setting. *Full* uses the entire 2022 test set; *excl. overlap* removes the test samples present in the 2022a surrogate training split. The change Δ is below 0.2 point in both settings. Experiments conducted using: the 2022a $\rightarrow$ 2021b training periods, Drebin feature space, five seeds, and seven classifiers.

Setting	ASR (full)	ASR (excl. overlap)	Δ
Matched	98.16 $\pm$ 0.6	98.11 $\pm$ 0.6	+0.05
All	86.27 $\pm$ 0.9	86.11 $\pm$ 0.6	+0.16

Table 12: **Ablation: AT Scaling,** unique AEs collected per AT-REPLICANT round with and without doubling training length every five rounds. The two schedules are near-identical over the first five rounds; however, the constant budget collapses monotonically as the target hardens, whereas the increasing budget continues to find AEs throughout the 15 rounds. Experiments conducted using: the 2021a $\rightarrow$ 2021b training period, Drebin feature space, five seeds, and seven classifiers.

Round	1	2	3	4	5
Increasing	16209	11398	6782	4060	1717
Constant	15776	11461	7329	4077	1930
	6	7	8	9	10
Increasing	1998	1635	913	558	541
Constant	865	352	211	159	134
	11	12	13	14	15
Increasing	3444	1464	1131	384	221
Constant	88	71	68	61	82